



UNIVERSITAT
Carlemany



UNIVERSITAT

Diseño y optimización de una arquitectura de red segura basada en principios Zero Trust para un despacho de servicios jurídicos

Segmentación, control de acceso y detección de intrusiones

Alumno: Joel Angel Balboa Arrojo

Tutor: Francisco Manuel Collazos Gámiz

Bàtxelor en Informàtica
Semestre 2. Edició 2025 - 2026
Junio 2026

ÍNDICE

ÍNDICE	2
1. Introducción y contextualización del proyecto	4
1.1. Descripción y situación inicial	4
1.2 Problema detectado y necesidades del cliente	5
1.3. Posibles soluciones valoradas	6
1.4. Design Thinking: empatizar, definir e idear	6
1.5. Diagrama de Ishikawa	8
1.6. Diagrama DAFO	9
2. Alcance del proyecto	10
2.1 Qué incluye el proyecto	10
2.2 Qué queda fuera del proyecto	11
2.3. Resumen elementos incluidos - excluidos del proyecto	13
2.4. Recursos disponibles y limitaciones	13
2.5 Requisitos Funcionales y No funcionales	15
2.6 Objetivos SMART y OKR	16
3. Planificación del proyecto	19
3.1. Lista de tareas e hitos	19
3.2. Dependencias entre tareas	20
3.3. Diagrama de Gantt	21
3.4. Diagrama PERT o camino crítico	22
4. Marco teórico	23
4.1 Arquitectura Zero Trust	23
4.2 Segmentación de redes mediante VLANs	24
4.3 Firewall de nueva generación	24
4.4 Sistemas de detección de intrusiones (IDS)	25
4.5 Auditoría de seguridad mediante escaneo de puertos	26
4.6 Entorno de emulación de redes	27
5. Diseño de topología y arquitectura	27

5.1 Diagramas de red	28
5.2 Distribución de Vlans	29
5.3 Tabla de direccionamiento	31
5.4 Matriz de comunicación entre zonas	31
5.5 Tabla de reglas	33
6. Entorno laboratorio	34
6.1 Entorno de virtualización	35
6.2 Appliances utilizados	36
6.3 Topología del laboratorio	38
6.4 Configuración base y validación del entorno	39
7. Auditoría inicial — situación PRE	40
7.1 Metodología y herramientas	40
7.2 Descubrimiento de hosts	41
7.3 Puertos y servicios con debilidades detectados	42
7.4 Línea base para la comparativa	44
X1. Bibliografía de referencia	45
X2. Anexos	46

1. Introducción y contextualización del proyecto

"Diseño y optimización de una arquitectura de red segura bajo principios Zero Trust para un despacho de servicios jurídicos: Segmentación, control de acceso y detección de intrusiones"

1.1. Descripción y situación inicial

Con el presente trabajo se busca abordar el diseño y la optimización de una arquitectura de red segura para una PYME del sector jurídico, aplicando principios acotados de Zero Trust e incorporando un sistema de detección de intrusiones mediante herramientas gratuitas y de código abierto, en un entorno de laboratorio simulado. Para comprobar el diferente nivel de exposición entre la situación inicial y la final se realizará una acotada auditoría de seguridad mostrando los puntos más importantes entre las dos situaciones.

El punto inicial, del que partimos es una infraestructura de red completamente plana, sin ninguna segmentación de red, seguridad en control de acceso ni monitorización del tráfico.

Con este escenario inicial buscamos reproducir la situación real de muchas PYMES y con más énfasis a las que tratan con información sensible y a su vez, sirviéndonos de base para poder comparar, la mejora de seguridad que puede aportar la solución propuesta.

La empresa sobre la que trabajaremos es una PYME ficticia con nombre Legal JBA y Asesores, tratándose de un despacho jurídico multidisciplinar de 18 empleados distribuidos en seis áreas: Mercantil, Laboral, Fiscal y Civil. El sector jurídico ha sido elegido especialmente porque presenta una justificación natural y sólida para la aplicación de principios Zero Trust, tratando información confidencial, protegida por el secreto profesional y que contiene datos de carácter personal especialmente sensibles en el sentido del Reglamento General de Protección de Datos (RGPD) y donde cada abogado debe tratar solo los expedientes que estén relacionados con su área.

La red actual de Legal JBA y Asesores responde a un modelo típico de crecimiento, partiendo inicialmente de unos pocos trabajadores y equipos hasta el actual estado, incorporando empleados, ampliando equipos, un servidor de expedientes y servicios de conectividad a medida que el despacho ha crecido, sin que en ningún momento se haya diseñado una arquitectura que contemple el control de acceso, la segmentación o la visibilidad del tráfico.

1.2 Problema detectado y necesidades del cliente

La situación descrita en el anterior apartado deriva en un problema central claramente identificable, la red de Legal JBA y Asesores presenta una exposición elevada ante accesos no autorizados y movimientos laterales, internos como externos, sin ningún mecanismo que permita detectarlos ni contenerlos.

El origen de esta exposición se analiza en los siguientes puntos además, vemos las siguientes necesidades concretas del cliente:

1. Necesidad de separación lógica en los recursos:

La red plana actual permite que cualquier dispositivo conectado acceda a los demás sin restricción. Se necesita segmentar la red de forma que los diferentes elementos (PCs, Servidor, Wi-Fi, Impresoras, Cámaras...) sean accesibles entre ellos solo si previamente se ha permitido, operando sino en entornos aislados y sin opción a poder saltar entre los diferentes elementos de red.

2. Control de acceso basado en el principio de mínimo privilegio:

No se debería poder acceder a recursos fuera de su área de trabajo. Se necesita un esquema de control de acceso que, a nivel de red, garantice que cada segmento funcional solo tenga visibilidad sobre los recursos estrictamente necesarios para su actividad.

3. Visibilidad y detección de comportamiento anómalo:

Actualmente el despacho no dispone de ningún mecanismo que le permita detectar accesos no autorizados, escaneos internos o movimientos laterales entre equipos. Se necesita una solución de monitorización que genere alertas ante tráfico sospechoso y tengamos trazabilidad de los eventos de que ocurren en la red.

4. Aislamiento de la red de invitados:

Como se ha comentado en el primer punto, actualmente existe una red lineal donde el servicio de Wi-Fi ofrecido a terceros es el mismo que el Wi-Fi interno corporativo. Se necesita una red de invitados que ofrezca acceso únicamente a internet y esté completamente aislada del resto de la infraestructura del despacho.

5. Acceso remoto seguro y controlado:

Los trabajadores que acceden remotamente a los recursos del despacho lo hacen a través de medios no controlados, VPN básica sin autenticación adicional, Anydesk, Teamviewer... Se necesita unificar el servicio a una solución VPN segura y reforzar este con medidas mínimas de verificación adicional.

6. Solución viable con recursos limitados:

El despacho no dispone de presupuesto histórico en seguridad ni de personal especializado. Cualquier solución debe ser implementable con herramientas de código abierto, sin coste de licencias, y gestionable por un equipo de IT reducido.

1.3. Posibles soluciones valoradas

Como posibles soluciones encontramos las siguientes:

- Solución 1:

Contratar una solución de seguridad gestionada de un proveedor que incluya firewall, gestión de identidad, IDS, segmentación como servicio...

Esta opción puede cubrir todas las necesidades identificadas, pero presenta un gran obstáculo para el contexto del proyecto. El coste de servicio, licencias y hardware es elevado para una PYME sin un presupuesto en comunicaciones y seguridad, siendo inviable aplicar soluciones en un espacio corto de tiempo, con lo que puede implicar seguir con la actual dinámica.

- Solución 2:

Realizar la segmentación on-premise con herramientas open source y principios Zero Trust acotados.

Diseñar e implementar en un entorno de laboratorio simulado (GNS3/EVE-NG) una arquitectura de red segmentada mediante VLANs, con firewall por zonas, control de acceso basado en roles, acceso remoto reforzado y despliegue de Suricata como sistema de detección de intrusiones. De esta forma, el coste es mínimo, con opción a ver si la mejora proporcionada es válida y pudiendo aplicarla en un corto espacio tiempo.

1.4. Design Thinking: empatizar, definir e idear

Con el fin de definir una solución alineada con las necesidades reales del cliente, se ha aplicado la metodología **Design Thinking**, centrando el análisis en las tres primeras fases: **empatizar, definir e idear**. Este enfoque permite comprender el contexto del despacho jurídico, identificar el problema principal y valorar distintas alternativas antes de seleccionar la solución que se desarrollará durante el proyecto.

Empatizar

Con la primera fase buscamos comprender el entorno de trabajo del cliente y que necesidades existen y condicionan la solución que buscamos aplicar.

Al tratarse de un despacho jurídico la actividad diaria de este implica el tratamiento continuo de documentos confidenciales, expedientes judiciales, contratos, información económica...

También vemos que, parte del personal necesita acceder ocasionalmente a los recursos corporativos desde ubicaciones externas, y que clientes y colaboradores utilizan la red inalámbrica de invitados cuando acuden a las oficinas.

La prioridad del despacho no consiste únicamente en proteger la infraestructura informática, sino en garantizar la confidencialidad de la información de sus clientes sin aumentar la complejidad de gestión ni realizar grandes inversiones.

A partir de este análisis se identifican las principales necesidades del cliente:

- Proteger la información confidencial frente a accesos no autorizados.
- Limitar la comunicación entre departamentos aplicando el principio de mínimo privilegio.
- Disponer de un acceso remoto seguro para el personal autorizado.
- Separar completamente la red corporativa de la red destinada a invitados.
- Detectar comportamientos anómalos o intentos de acceso indebidos mediante mecanismos de monitorización.
- Implantar una solución técnicamente viable utilizando herramientas de código abierto y un coste reducido.

Estas necesidades complementan las descritas en el anterior apartado 1.2, permitiendo comprender no solo los problemas técnicos que existen, sino también las limitaciones organizativas y económicas de la empresa.

Definir

Tras analizar el contexto general del despacho, se identifica un problema principal que resume la situación actual de la infraestructura.

La red corporativa ha evolucionado conforme el despacho ha ido creciendo, ampliando los equipos y servicios sin una planificación específica de red y seguridad. Como consecuencia, todos los dispositivos comparten un mismo segmento de red y existe una confianza implícita entre ellos.

Esta situación nos muestra que existen diversos riesgos:

- Cualquier dispositivo puede comunicarse con el resto de la red y por tanto comprometerla de diferentes formas .
- Los usuarios disponen de una visibilidad superior a la necesaria.
- No existen herramientas capaces de detectar movimientos laterales o actividades sospechosas.
- El acceso remoto se realiza mediante herramientas inseguras y sin controles adicionales.
- La red inalámbrica utilizada por invitados comparte recursos con la red corporativa.

En consecuencia, el problema que buscamos abordar podría definirse como:

La infraestructura de red de Legal JBA y Asesores presenta una elevada exposición frente a accesos no autorizados y movimientos laterales debido a la ausencia de segmentación, control de acceso y mecanismos de monitorización de seguridad.

Idear

Con el problema identificado, se establecen diferentes soluciones teniendo en cuenta las necesidades del cliente, las limitaciones presupuestarias y el alcance establecido.

En primer lugar, se valoró la posibilidad de implantar una solución comercial completamente gestionada, integrando firewall de nueva generación, sistemas de detección de intrusiones, gestión centralizada de identidades y otros mecanismos avanzados de seguridad. Aunque esta alternativa proporciona un elevado nivel de protección, requiere una inversión económica significativa y un nivel de especialización técnica que no resulta compatible con el escenario planteado.

Como segunda alternativa, se estudió el diseño de una arquitectura basada en herramientas de código abierto, implementada en un entorno de laboratorio.

Esta opción permite reproducir un escenario representativo, aplicar principios de Zero Trust de forma acotada y validar si existe una mejora de seguridad mediante auditorías de seguridad antes y después de la implementación.

Tras comparar ambas posibilidades, se selecciona la segunda alternativa al ofrecer un equilibrio adecuado entre seguridad, viabilidad técnica y coste de implantación. La solución propuesta contempla la segmentación de la red mediante VLAN, la aplicación de políticas de firewall, el aislamiento de la red de invitados, la incorporación de un acceso remoto seguro y el despliegue de Suricata como sistema de detección de intrusiones.

Esta propuesta permite responder a las necesidades identificadas durante las anteriores fases de empatía y definición, manteniendo un alcance realista y plenamente alineado con los objetivos del proyecto.

1.5. Diagrama de Ishikawa

Con el objetivo de identificar las causas originarias del problema principal, se ha elaborado el siguiente diagrama de Ishikawa.

Este análisis permite representar de forma estructurada los factores relacionados con la tecnología, el entorno, los procesos, las alertas, las personas y la gestión, todos factores que contribuyen a la elevada exposición de la infraestructura de red frente a accesos no autorizados y movimientos laterales.

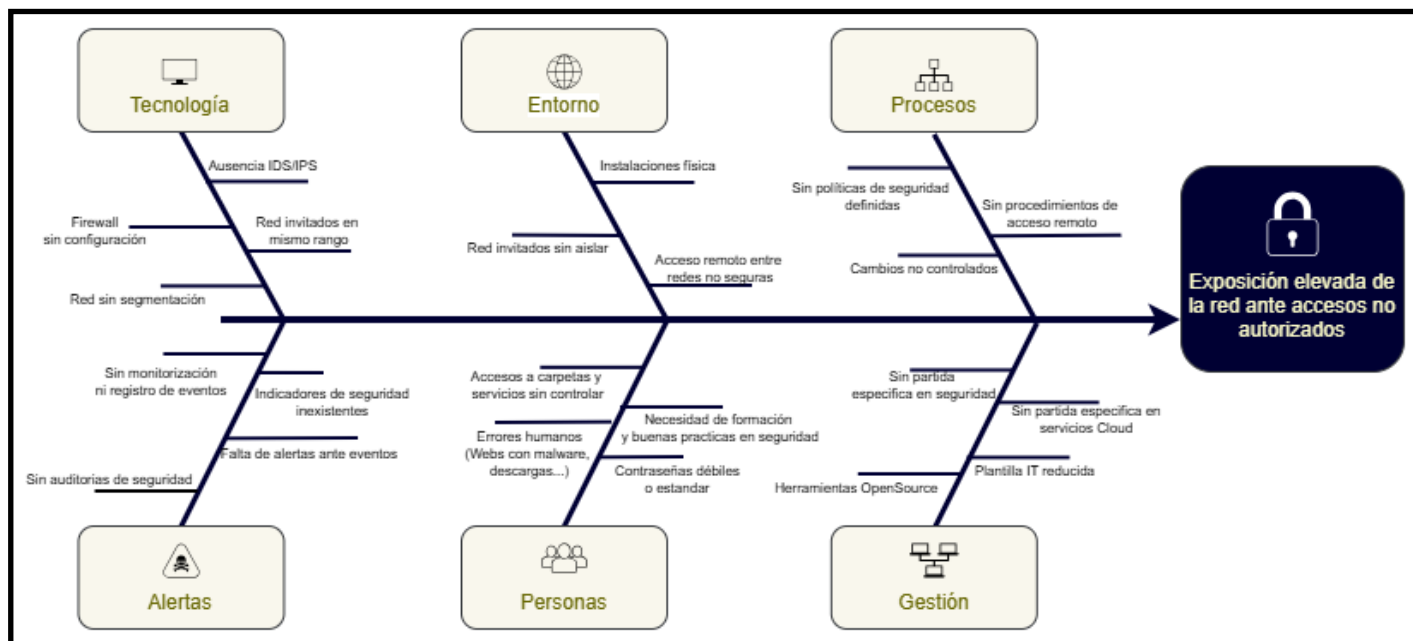


Figura 1. Diagrama de Ishikawa. *Elaboración propia.*

1.6. Diagrama DAFO

Complementando la anterior Figura1. Diagrama de Ishikawa, se presenta la siguiente Figura2. Análisis DAFO, que permite evaluar la situación actual de Legal JBA y Asesores desde una perspectiva más estratégica.

Este análisis identifica las fortalezas y debilidades internas, las oportunidades y las amenazas externas, permitiendo una correcta adecuación y justificación de la solución propuesta a las necesidades del cliente.

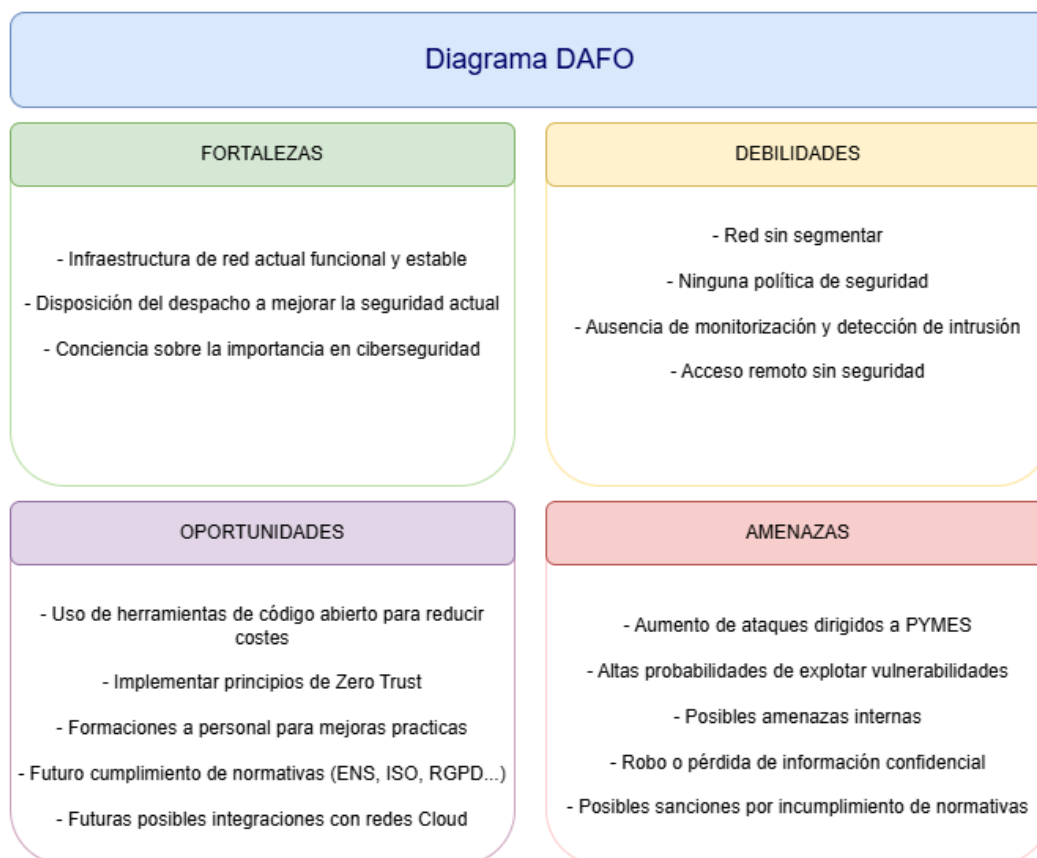


Figura 2. Análisis DAFO — Legal JBA y Asesores. *Elaboración propia.*

2. Alcance del proyecto

2.1 Qué incluye el proyecto

El proyecto se centra en el diseño, implementación y validación de una arquitectura de red segura para el despacho jurídico ficticio Legal JBA y Asesores, configurado en un entorno virtualizado de laboratorio, partiendo de una red inicial completamente plana y sin segmentación.

Los elementos que forman parte del alcance son los siguientes:

- Diseño de topología segmentada:

Definición de un diseño de red dividida en zonas diferenciadas mediante zonas y VLANs: áreas jurídicas (Mercantil, Laboral, Fiscal, Civil), administración/IT, servidores y red de invitados.

Se incluye la situación inicial con el diagrama de red base y el diagrama con la solución final objetivo, la tabla de direccionamiento y las reglas de comunicación entre segmentos.

- Implementación en entorno de laboratorio simulado:

Toda la implementación se realizará en un entorno simulado mediante GNS3 o EVE-NG. Se incluye la configuración de los elementos de red virtuales necesarios: switches con soporte de VLANs, firewall con las políticas entre zonas y los dispositivos finales representativos que sean necesarios en cada segmento.

- Control de acceso a nivel de red:

Aplicación de principios de mínimo privilegio mediante reglas de firewall y ACLs entre VLANs. Cada segmento tendrá permitido únicamente el tráfico estrictamente necesario para su función, bloqueando por defecto cualquier comunicación no autorizada entre zonas.

- Acceso remoto reforzado:

Configuración de una solución VPN como único mecanismo de acceso remoto a los recursos del despacho, sustituyendo el uso actual de herramientas no controladas (AnyDesk, TeamViewer, ...). Se añadirán medidas mínimas para la verificación de acceso.

- Red de invitados diferenciada:

Configuración de una red de invitados con acceso únicamente a internet, completamente aislada de la red corporativa interna.

- Despliegue de sistema IDS:

Instalación y configuración de Suricata como sistema de detección de intrusiones en el entorno simulado, con generación de alertas ante tráfico de prueba controlado.

- Auditoría de seguridad pre/post implementación:

Ejecución de auditorías de exposición con Nmap (descubrimiento, escaneo de puertos y scripts NSE) y verificación manual de acceso a los servicios detectados, para la situación inicial y la situación final, utilizando las mismas herramientas y métricas para garantizar una correcta comparativa en los resultados.

Ambas auditorías se ejecutarán desde el mismo equipo atacante virtual, utilizando el mismo perfil de escaneo y desde la misma zona de red, garantizando así la comparabilidad de los resultados.

- Documentación técnica completa:

Memoria del proyecto con las decisiones de diseño justificadas, pasos de configuración, capturas de evidencia y análisis comparativo pre/post.

2.2 Qué queda fuera del proyecto

Con el siguiente apartado queremos delimitar explícitamente los elementos que podrían considerarse relevantes para una arquitectura de red segura completa pero que, quedan excluidos del alcance de este TFB.

Esta delimitación responde a criterios de viabilidad técnica, temporal y de recursos, esto no implica que dichos elementos carezcan de valor.

1. Integración con servicios cloud

La conectividad con entornos cloud, configuración de redes virtuales y la gestión de identidad mediante soluciones como Microsoft Entra ID quedan fuera del alcance de este proyecto.

Su implementación requeriría licencias, servicios de pago y una complejidad de integración que excede los recursos disponibles y el enfoque de red on-premise del TFB. Se añade y documenta como línea de mejora futura, siendo un de los siguientes pasos lógicos una vez consolidada la arquitectura on-premise.

2. Gestión centralizada de identidad y Directorio Activo

No se implementará ningún servidor de Directorio Activo (Active Directory / LDAP) ni solución de Single Sign-On. El control de acceso se aplica íntegramente a nivel de red mediante VLANs, ACLs y reglas de firewall, que es el enfoque propio de un proyecto de diseño de red.

La gestión de identidad centralizada se propone como mejora futura complementaria a la integración cloud.

3. Alta disponibilidad y redundancia

No se contemplan configuraciones de alta disponibilidad, como enlaces redundantes, balanceo de carga o failover entre los diferentes dispositivos.

El entorno de laboratorio simulado no requiere estos elementos para validar los objetivos de seguridad definidos.

4. Explotación activa y auditoría de seguridad avanzada

La validación de la solución se limita a una breve auditoría de los servicios expuestos pre/post con Nmap y verificación manual de acceso.

No se realizarán pruebas de penetración activa, explotación de vulnerabilidades ni análisis forense. El objetivo es solo medir la reducción de exposición, no ejecutar un test de intrusión profesional completo.

5. Despliegue sobre infraestructura real

El proyecto se desarrolla en un entorno de laboratorio simulado mediante GNS3. No se realizará ninguna implementación sobre equipos físicos reales ni sobre la infraestructura de ninguna empresa.

6. Múltiples herramientas IDS/IPS en paralelo

Solo se desplegará Suricata como sistema de detección de intrusiones. No se compararán ni se implementarán soluciones IDS entre sí. El objetivo es validar el funcionamiento del IDS elegido, no realizar un análisis comparativo de herramientas.

2.3. Resumen elementos incluidos - excluidos del proyecto

TAREA	INCLUIDO EN PROYECTO	EXCLUIDO EN PROYECTO
Segmentación Vlans	X	
Firewall con zonas	X	
IDS Suricata	X	
Acceso remoto VPN seguro	X	
Aislamiento de red Wi-Fi invitados	X	
Auditoría pre-implementación	X	
Auditoría post-implementación	X	
Integración con elementos Cloud		X
AD / Gestión de identidades		X
Alta disponibilidad y redundancia		X
Despliegue en infraestructura real		X
Comparativa de herramientas		X
Pentest interno		X

2.4. Recursos disponibles y limitaciones

Las siguientes tablas exponen los recursos disponibles que se utilizarán en el proyecto.

En esta primera tratamos los recursos que se utilizan en el proyecto:

Elemento	Recurso elegido	Descripción
Base de simulación de red	3 GNS	Entorno de laboratorio virtual para simular la topología de red completa
IDS/IPS	Suricata	Sistema de detección de intrusiones open source
Firewall	pfSense / OPNsense	Solución de firewall open source

Elemento	Recurso elegido	Descripción
Auditoría	Nmap	Escáner de descubrimiento, puertos y servicios para auditoría pre/post
Software	VirtualBox / VMware / KVM	Hipervisor para alojar y gestionar los nodos de laboratorio
Hardware	Maquina personal del alumno	Máquina con los recursos necesarios y suficientes para ejecutar el entorno virtual

Para esta segunda tabla, dado que el proyecto se basa íntegramente en herramientas de código abierto y en infraestructura propia, el coste económico directo es nulo. A continuación se expone una estimación orientativa del coste interno del proyecto:

Elemento	Coste aproximado	Descripción
Licencias y software	0 €	Todas las herramientas que se tratan en el proyecto son de código abierto y gratuitas
Hardware	0 €	El equipo utilizado es el propio personal, no existe ningún coste de nuevo hardware
Servicios Cloud o alojamiento	0 €	El entorno que se prepara es totalmente en local y no es necesario adquirir soluciones Cloud
Dedicación equipo	330 Horas x 10€/H = 3.300€	Coste interno estimado, es orientativo a 30H por 11 semanas.
Otros costes adicionales	0 €	No existe ningún otro coste adicional que sea necesario para el proyecto

Como limitaciones que podemos encontrar en nuestro proyecto:

- Entorno exclusivamente simulado:

No se dispone de acceso a infraestructura física real.

Todos los resultados se obtienen en un entorno de laboratorio virtualizado, lo que implica que valores de métricas como latencia, rendimiento, carga, etc... no son extrapolables directamente a un entorno de producción real. Los resultados son válidos a efectos de comparación relativa pre/post.

- Equipo de IT reducido en el escenario ficticio:

Legal JBA y Asesores cuenta con un perfil de IT reducido y sin especialización en seguridad, lo que limita la complejidad de las soluciones que se pueden proponer

como implementables de forma autónoma por el despacho. Las soluciones elegidas priorizan la viabilidad operativa sobre la exhaustividad técnica.

- Sin presupuesto para licencias comerciales:

Todas las herramientas utilizadas son de código abierto y gratuitas. Quedan excluidas soluciones que requieran licencias de pago, suscripciones cloud o hardware específico de fabricante.

- Alcance acotado de Zero Trust:

Los principios Zero Trust se aplican de forma acotada al nivel de red: segmentación, mínimo privilegio y control de acceso por VLANs. No se implementarán otros puntos de Zero Trust como verificación continua de identidad, inspección profunda de paquetes o gestión de dispositivos endpoint entre otros.

2.5 Requisitos Funcionales y No funcionales

Los requisitos funcionales describen qué debe hacer el sistema para satisfacer las necesidades identificadas. Se indica para cada uno el criterio que permitirá verificar su cumplimiento.

ID	Requisito	Criterio comprobación
RF01	La red deberá dividirse en zonas diferenciadas: Usuarios, administración / IT, invitados	Diagrama de red final VLANs etiquetadas y reglas de comunicación
RF02	El firewall deberá aplicar reglas de filtrado entre zonas siguiendo el principio de mínimo privilegio. Permitiendo solo tráfico estrictamente necesario	Tabla de reglas permitidas y bloqueadas, con pruebas de conectividad
RF03	La red de invitados deberá estar completamente aislada de la red corporativa, permitiendo únicamente acceso a internet	Prueba de conectividad desde la red de invitados hacia recursos internos: denegado
RF04	El sistema IDS (Suricata) deberá detectar y registrar tráfico sospechoso ante pruebas controladas de escaneo interno	Capturas de alertas generadas durante las pruebas de validación
RF05	La solución deberá incluir un mecanismo de acceso remoto reforzado para el personal que trabaja fuera de la oficina	Evidencia de configuración y prueba de acceso remoto con las medidas aplicadas

Los requisitos no funcionales describen las condiciones y restricciones bajo las cuales el sistema debe operar, independientemente de su funcionalidad específica.

ID	Requisito	Criterio comprobación
RNF01	La solución deberá implementarse íntegramente con herramientas de código abierto, sin coste de licencias	Inventario de las herramientas utilizadas
RNF02	El entorno de implementación será un laboratorio simulado. No se realizará ningún despliegue sobre infraestructura real	Descripción del entorno utilizado y capturas de la topología
RNF03	La documentación generada deberá permitir reproducir la configuración básica de forma independiente	Pasos de configuración, capturas de pantalla y anexos técnicos
RNF04	La evaluación de la mejora de seguridad deberá comparar el estado inicial y el estado final utilizando las mismas herramientas y métricas	Tabla comparativa pre/post con métricas equivalentes: puertos expuestos, debilidades de configuración confirmadas, alertas

2.6 Objetivos SMART y OKR

Objetivo SMART

ID OS01	Descripción
	Caracterizar la situación inicial de la red de Legal JBA
Específico	Diagrama de red base, inventario de activos y auditoría inicial
Medible	Puertos, servicios y debilidades de configuración detectadas
Alcanzable	Con herramienta Nmap y verificación manual en laboratorio controlado
Relevante	Nos marca una línea de inicio base pre-implementación
Temporal	Fase 1

ID OS02	Descripción
	Diseño de una topología segmentada
Específico	Creación de al menos 4 zonas diferenciadas (usuarios, administración/IT, servidores, invitados) con tabla de reglas entre zonas
Medible	Diagrama de red validado y tabla de comunicaciones
Alcanzable	Con implementación en GNS3/EVE-NG

ID OS02	Descripción
Relevante	Elimina la red plana actual y se establecen bases para las siguientes fases del proyecto
Temporal	Fase 2-3

ID OS03	Descripción
	Implementar segmentación y firewall por zonas
Específico	VLANs activas y reglas de firewall aplicando mínimo privilegio a nivel de red
Medible	Pruebas de conectividad entre las diferentes zonas, documentación de accesos permitidos y denegados
Alcanzable	Con herramientas open source en laboratorio
Relevante	Parte principal técnica del proyecto
Temporal	Fase 4

ID OS04	Descripción
	Desplegar solución IDS
Específico	Desplegar IDS Suricata operativo y configurado en el entorno simulado
Medible	Configuración de alertas y registros ante pruebas controladas de escaneo interno
Alcanzable	Herramienta open source Suricata
Relevante	Cubrir la necesidad de visibilidad del tráfico
Temporal	Fase 5

ID OS05	Descripción
	Comparar métricas de exposición pre/post
Específico	Realizar comparación con las mismas herramientas y métricas
Medible	Reducción de puertos expuestos, debilidades de configuración y accesos no autorizados
Alcanzable	Reproducible en laboratorio, con herramienta Nmap y verificación manual
Relevante	Demostrar el valor real de la solución ofrecida.
Temporal	Fase 6

ID OS06	Descripción
	Documentar decisiones técnicas y líneas futuras
Específico	Ofrecer una diferenciación clara entre el alcance implementado y lo propuesto como mejora
Medible	Apartados de limitaciones y mejoras futuras presentes en la memoria
Alcanzable	Aportando documentación necesaria
Relevante	Ofrecer futuras líneas de ampliación del proyecto
Temporal	Fase 7

Objetivo OKR

Mejorar la seguridad de la red de un despacho jurídico mediante una arquitectura segmentada con principios Zero Trust acotados, validada en entorno de laboratorio.

ID	Métrica clave
KR1	Reducir al menos un 70% el número de puertos accesibles desde la red de invitados hacia la red corporativa, medido con Nmap antes y después de la implementación
KR2	Bloquear el 100% de las pruebas de conectividad no autorizada entre VLANs, documentando cada regla de firewall aplicada y el resultado de la prueba correspondiente
KR3	Registrar al menos una alerta en Suricata por cada prueba de escaneo controlado ejecutada, con un tiempo de detección inferior a 60 segundos desde el inicio del escaneo
KR4	Presentar una tabla comparativa pre/post con un mínimo de 4 métricas equivalentes: puertos expuestos, servicios accesibles entre zonas no autorizadas, debilidades de configuración confirmadas mediante Nmap, verificación manual y alertas IDS generadas
KR5	Documentar posibles líneas de mejora futura con justificación técnica

3. Planificación del proyecto

3.1. Lista de tareas e hitos

El proyecto se estructura en diez fases, con tareas concretas, duración estimada y un resultado tangible que actúa como criterio de cierre de fase.

También se señalan hitos que marcan puntos de control marcados en el desarrollo del trabajo.

ID	Título	Descripción	Tiempo estimado	Entrega asociada
F1	Definir alcance del proyecto	Creación de Legal JBA y Asesores, análisis de la situación inicial, necesidades, Design Thinking, diagramas Ishikawa y DAFO	1 semana	Entregable 1
F2	Marco teórico	Revisión de conceptos clave: Zero Trust, segmentación de red, VLANs, IDS/IPS, auditoría de seguridad	1 semana	Entregable 2
F3	Preparación de la arquitectura	Diagrama de red en situación inicial y diagrama de red objetivo. Tabla de VLANs, direccionamiento y reglas de comunicación entre zonas	1 semana	Entregable 2
F4	Preparación del laboratorio	Instalación y configuración de GNS3/EVE-NG. Despliegue de switches, firewall y equipos representativos de cada segmento	1 semana	Entregable 2
F5	Auditoría inicial	Ejecución de auditoría sobre la red plana inicial. Registro de puertos expuestos, servicios accesibles detectados	2-4 días	Entregable 2
F6	Implementación principal	Configuración de VLANs, definición y aplicación de reglas de firewall con mínimo privilegio entre segmentos. Pruebas de conectividad entre zonas	1 semana	Entregable 2
F7	Acceso remoto	Creación de VPN unificada. Configuración de medidas mínimas de verificación adicional para el acceso remoto	2-4 días	Entregable 2/3
F8	Implementación IDS	Instalación y configuración de Suricata en el entorno simulado. Ejecución de pruebas controladas de escaneo interno. Registro y análisis de alertas generadas	2-4 días	Entregable 2/3
F9	Auditoría final	Ejecución de segunda auditoría sobre la red segmentada final. Elaboración de la tabla comparativa con las mismas métricas que la auditoría inicial	1 semana	Entregable 3

ID	Título	Descripción	Tiempo estimado	Entrega asociada
F10	Redacción final	Redacción de la memoria final, revisión de contenidos, entrega del TFB y preparación de defensa	3 semanas	Entregable 3

A partir de las anteriores fases, se identifican los hitos principales.

Un hito representa un punto de control concreto y que se pueda verificar, que permita confirmar que una fase o conjunto de fases ha producido el resultado esperado antes de continuar con la siguiente etapa.

Es importante señalar que las fases F2 y F3 pueden ejecutarse en paralelo durante la misma semana, al no tener dependencia entre sí. Del mismo modo, las fases F7 y F8 también pueden desarrollarse simultáneamente una vez completada la F6.

La fase F6 Implementación principal actúa como punto crítico del proyecto: cualquier retraso en esta fase afecta directamente a F7, F8 y, en consecuencia, a toda la planificación posterior.

ID	Descripción	Alcanzable
H1	Entregable 1 realizado y entregado	22/06/2026 - 28/06/2026
H2	Arquitectura diseñada y validada	05/07/2026
H3	Creación de entorno de laboratorio	12/07/2026
H4	Auditoría inicial	15/07/2026
H5	Segmentación finalizada con firewall operativo	19/07/2026
H6	Implementación completa (VPN, IDS, Wi-Fi)	20/07/2026 - 26/07/2026
H7	Comparativa pre/post completada	09/08/2026
H8	Entrega de TFB	31/08/2026 - 06/09/2026

3.2. Dependencias entre tareas

Con la siguiente tabla buscamos exponer las relaciones de dependencia que existen entre fases.

De forma general, una fase no puede iniciarse hasta que la anterior fase o fases de las que depende no estén completadas.

Fase	Dependencia	Descripción
F1. Definir alcance del proyecto	-	Punto inicial
F2. Marco teórico	F1	Necesitamos saber previamente que trabajaremos para determinar los conceptos necesarios
F3. Preparación de la arquitectura	F1	Requiere saber el escenario inicial
F4. Preparación del laboratorio	F3	Configuramos el laboratorio en base a F3
F5. Auditoría inicial	F4	Auditoría realizada sobre el laboratorio creado en la anterior fase
F6. Implementación principal	F5	Para establecer la implementación principal necesitamos antes saber de que partimos, tanto a nivel arquitectura como también vulnerabilidades
F7. Acceso remoto	F6	Integración necesaria una vez tenemos los elementos principales configurados
F8. Implementación IDS	F6	Integración que necesita la parte principal configurada
F9. Auditoría final	F7 y F8	Se requiere que todos los elementos de la solución estén implementados
F10. Redacción final	F9	Para la memoria final necesitamos integrar todos los resultados, incluida la comparativa

3.3. Diagrama de Gantt

Para establecer una correcta planificación del proyecto y que sea de forma organizada y poder garantizar el cumplimiento de los plazos, se ha elaborado el siguiente diagrama de Gantt.

En él se representan las principales fases, hitos, fecha entregables y la distribución temporal, permitiendo visualizar la secuencia de actividades necesarias para el diseño, implementación y validación de la solución propuesta.

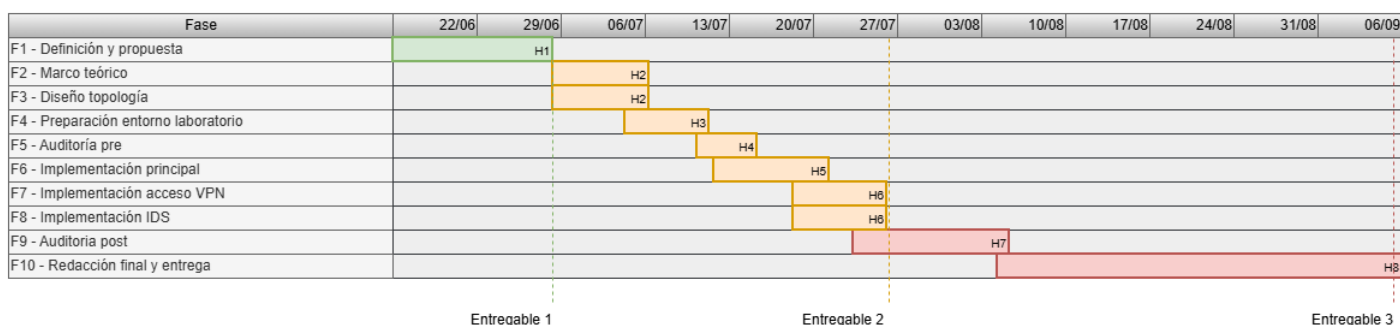


Figura 3. Diagrama de Gantt. *Elaboración propia.*

3.4. Diagrama PERT o camino crítico

Con el objetivo de identificar la secuencia lógica de ejecución del proyecto y las dependencias que existen entre las diferentes fases, se ha elaborado el siguiente diagrama PERT.

Este diagrama representa las relaciones de precedencia entre las diferentes tareas principales, permitiendo ver el camino de ejecución del proyecto y aquellas actividades cuya finalización condiciona el inicio de las fases posteriores. De este modo, facilita la planificación, el seguimiento del proyecto y la identificación de los puntos críticos durante su desarrollo.

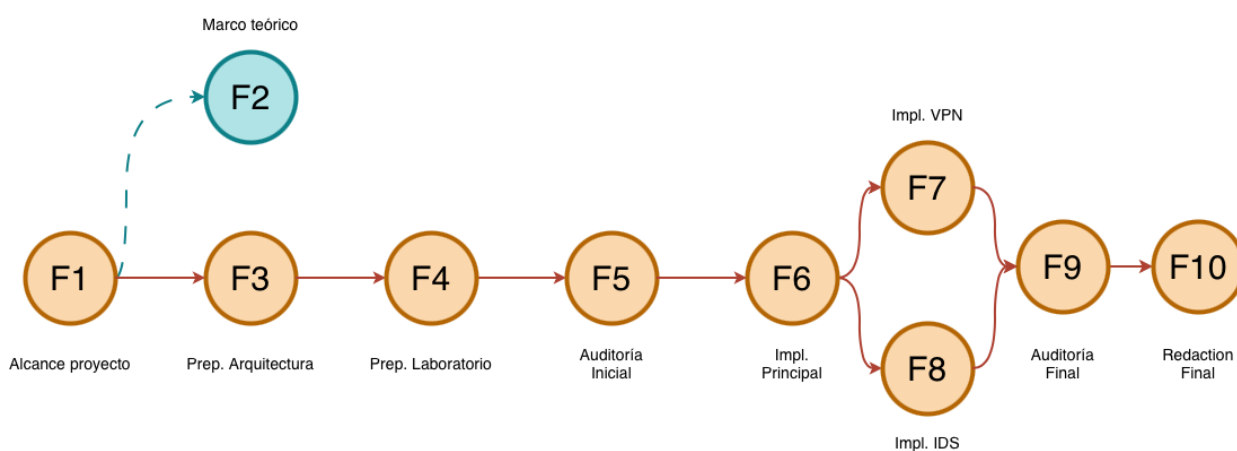


Figura 4. Diagrama de PERT. *Elaboración propia.*

Como puede observarse, el camino crítico del proyecto está formado en casi su totalidad por fases cuya finalización es necesaria para poder ejecutar la siguiente. Cualquier retraso en estas tareas afectaría directamente al calendario previsto, por lo que requieren un seguimiento prioritario durante el desarrollo del proyecto.

La única fase que se podría permitir un breve retraso es F2 Marco teórico, siendo no aconsejable ya que, obtener una buena base teórica permite que las siguientes fases puedan ser ejecutada con mayor precisión.

Por último, en el caso de F7 Implementación VPN y F8 Implementación IDS, son las únicas que no tienen dependencia una de otra, pudiendo ejecutarse en paralelo.

4. Marco teórico

Antes de abordar el diseño de la arquitectura de red, se presentan a continuación los conceptos y tecnologías en los que se fundamenta la solución propuesta.

El paradigma de seguridad Zero Trust como marco de referencia, la segmentación de redes mediante VLANs como mecanismo de aislamiento, los cortafuegos de nueva generación y los sistemas de detección de intrusiones como elementos de control y visibilidad, herramientas básicas de auditoría y emulación de redes empleadas para validar la solución en un entorno de laboratorio.

4.1 Arquitectura Zero Trust

El modelo de seguridad perimetral tradicional parte de la premisa de que todo lo que se encuentra dentro de la red corporativa es de confianza, y que la principal barrera de protección es el perímetro, con un firewall justo antes de la salida a internet. Este enfoque presenta una debilidad estructural, una vez que un atacante o un dispositivo comprometido consigue acceso a la red interna se encuentra habitualmente muy pocas restricciones para moverse lateralmente hacia otros sistemas, precisamente la situación descrita en el diagnóstico inicial de este trabajo.

Frente a este modelo, el NIST Special Publication 800-207, Zero Trust Architecture (2020), formaliza un conjunto de principios que parten de la premisa contraria, ninguna solicitud de acceso se considera de confianza por el mero hecho de originarse dentro de la red corporativa, toda comunicación debe ser autenticada, autorizada y limitada al mínimo privilegio necesario, con independencia de su origen.

Entre los principios que recoge esta publicación, y que resultan directamente aplicables a este proyecto, destacan:

- Verificación explícita: cada solicitud de acceso se evalúa de forma individual, no se asume confianza por pertenecer a la misma red.
- Mínimo privilegio: cada usuario o sistema accede únicamente a los recursos estrictamente necesarios para su función.
- Segmentación o microsegmentación: la red se divide en zonas reducidas y aisladas entre sí, de forma que el compromiso de una zona no implique el compromiso del resto.

Este proyecto no implementa una arquitectura Zero Trust completa en el sentido estricto de la publicación NIST, donde vemos que se contemplan otros elementos mucho mas sofisticados como motores de políticas dinámicas o verificación continua de identidad a nivel de sesión, sino que busca establecer unas bases y una aplicación acotada de sus principios mediante los mecanismos disponibles en un entorno de laboratorio con herramientas open source, segmentación por VLANs, control de acceso mediante reglas de firewall con lógica deny-by-default, y monitorización mediante un sistema de detección de intrusiones.

Esta acotación queda reflejada explícitamente en el alcance del proyecto (apartado 2) y en el propio objetivo OKR, que se refiere a *"una arquitectura segmentada con principios Zero Trust acotados"*.

4.2 Segmentación de redes mediante VLANs

Una VLAN (*Virtual Local Area Network*) es un mecanismo que permite dividir una misma infraestructura física de red en múltiples dominios de difusión lógicamente independientes, sin necesidad de desplegar cableado ni conmutadores separados para cada uno. El estándar que define este etiquetado de tráfico es IEEE 802.1Q, donde se añade una marca (*tag*) a cada trama Ethernet indicando a qué VLAN pertenece, permitiendo que un mismo enlace físico (*trunk*) transporte el tráfico de varias VLANs de forma simultánea y aislada.

Desde el punto de vista de la seguridad, la segmentación mediante VLANs es el mecanismo técnico que hace posible aplicar en la práctica los principios de mínimo privilegio y microsegmentación descritos en el apartado 4.1, al situar cada zona funcional en un dominio de difusión independiente, ningún dispositivo puede comunicarse con otro fuera de su VLAN sin pasar obligatoriamente por un elemento que enrute entre ellas. En el caso de este proyecto con el firewall OPNsense, que es donde se aplicaran las reglas de control de acceso.

Esta es precisamente la transformación central que busca el diseño de red del siguiente apartado 5, pasar de la situación inicial con un único dominio de difusión sin ninguna separación entre áreas, a una arquitectura donde cada área jurídica, la zona de IT, la infraestructura de gestión y la red de invitados constituyen VLANs independientes, eliminando la posibilidad de movimiento lateral directo entre ellas.

La configuración de VLANs sobre firewalls basados en FreeBSD como pfSense y OPNsense sigue un patrón común, se crean interfaces virtuales (subinterfaces) sobre una interfaz física, cada una asociada a un identificador de VLAN (VLAN ID) y con su propia configuración de red, tal como se detalla en la documentación oficial de ambos proyectos.

4.3 Firewall de nueva generación

Un firewall es el elemento de red encargado de inspeccionar el tráfico que atraviesa un punto de la infraestructura y decidir, en función de un conjunto de reglas, qué comunicaciones se permiten y cuáles se bloquean. Los cortafuegos tradicionales basan esta decisión únicamente en direcciones IP y puertos pero los denominados firewalls de nueva generación (*Next-Generation Firewall*, NGFW) amplían esta inspección incorporando funcionalidades adicionales sobre la misma plataforma, filtrado con estado de las conexiones, reglas organizadas por zonas o interfaces, traducción de direcciones (NAT), redes privadas virtuales (VPN), integración con sistemas de detección de intrusiones... evitando así desplegar un dispositivo independiente para cada función.

En este proyecto se emplea OPNsense, un cortafuegos de nueva generación de código abierto basado en FreeBSD, derivado del proyecto pfSense. Se ha optado por OPNsense frente a pfSense por dos motivos principales: por un lado, su modelo de desarrollo permite ciclos de actualización más frecuentes y por otro, incorpora de forma nativa el paquete de integración con Suricata que se utiliza como sistema de detección de intrusiones, evitando así desplegar un sensor IDS como elemento adicional separado del propio cortafuegos.

La política de seguridad aplicada sigue el principio descrito en el apartado 4.1 del modelo Zero Trust, el deny-by-default donde por defecto, ninguna comunicación entre zonas está permitida y únicamente se habilita y permite el tráfico que ha sido explícitamente autorizado mediante una regla, evaluada en orden, de la más específica a la más general, hasta llegar a una regla de cierre final que bloquea cualquier tráfico no contemplado. Siendo este el criterio que se ha diseñado para la matriz de comunicación entre zonas y su traducción a reglas concretas de firewall (reglas R01 a R12 del apartado 5.5).

Adicionalmente, OPNsense puede actuar como servidor de DHCP para las distintas VLANs y realiza la función de NAT (traducción de direcciones de red) para permitir la salida a internet de los equipos internos utilizando una única dirección pública, sin necesidad de que estos dispongan de direccionamiento enrutable directamente.

4.4 Sistemas de detección de intrusiones (IDS)

Un sistema de detección de intrusiones (*Intrusion Detection System*, IDS) es un elemento que analiza el tráfico de red en busca de patrones asociados a actividad maliciosa o anómala como pueden ser escaneos de puertos, explotación de vulnerabilidades conocidas o tráfico hacia dominios maliciosos entre otros, generando alertas cuando los detecta. Conviene distinguirlo de un sistema de prevención de intrusiones (*Intrusion Prevention System*, IPS) ya que, aunque puedan parecer lo mismo existen diferencias entre ellos. El IDS opera de forma pasiva, limitándose a observar y alertar, un IPS se sitúa en línea con el tráfico y tiene capacidad de bloquearlo activamente. Ambos modos suelen implementarse sobre el mismo motor de software, variando únicamente su modo de despliegue (pasivo mediante espejo de tráfico, o en línea).

En este proyecto se emplea Suricata, un motor de detección de intrusiones de código abierto desarrollado por Open Information Security Foundation (OISF), que analiza el tráfico de red contra un conjunto de reglas (*rulesets*) que describen firmas de amenazas conocidas, el conjunto de reglas abierto ET Open (Emerging Threats). Suricata se ha desplegado en modo de detección (IDS), integrado directamente en el perímetro definido por el cortafuegos OPNsense, en lugar de como sensor independiente, permitiendo que Suricata inspeccione el tráfico que atraviesa las distintas zonas sin necesidad de configurar un puerto espejo (SPAN) adicional ni desplegar un nodo dedicado.

El propósito de Suricata dentro de la arquitectura no es sustituir a las reglas de firewall como mecanismo de control de acceso, sino aportar una capa de visibilidad y

verificación. Mientras que las reglas de firewall determinan qué tráfico está permitido o bloqueado, Suricata permite comprobar, mediante la generación de alertas, si efectivamente se están produciendo intentos de tráfico no autorizado.

Por ejemplo, un intento de escaneo de puertos desde la VLAN de invitados hacia otra zona, con independencia de que dicho intento haya sido o no bloqueado por el firewall. Esta capacidad es la que sustenta la métrica de "alertas IDS generadas" contemplada en el KR4 como parte de la comparativa pre/post.

4.5 Auditoría de seguridad mediante escaneo de puertos

La auditoría de exposición de red es el proceso de identificar, desde la perspectiva de un atacante, qué dispositivos son alcanzables en una red, qué puertos tienen abiertos y qué servicios exponen en ellos, información que constituye la superficie de ataque real de la infraestructura. A diferencia de un análisis de vulnerabilidades exhaustivo donde se busca correlacionar los servicios detectados contra bases de datos de fallos conocidos, CVE, y les asigna una severidad, el escaneo de puertos se centra en responder una pregunta más básica pero igualmente crítica: "*qué es visible y accesible*", con independencia de si el software instalado tiene o no vulnerabilidades específicas.

La herramienta empleada para esta auditoría es Nmap (Network Mapper), un escáner de red de código abierto que constituye el estándar de facto para este tipo de tareas. Nmap permite, entre otras funciones:

- Descubrimiento de hosts: determinar qué direcciones IP de un rango dado corresponden a dispositivos activos, mediante técnicas como el escaneo ARP (en redes locales) o el envío de paquetes ICMP/TCP.
- Escaneo de puertos: identificar, para cada host activo, qué puertos TCP/UDP se encuentran en estado abierto, cerrado o filtrado.
- Detección de versión de servicio (-sV): identificar, mediante el análisis de las respuestas del servicio, qué software y qué versión concreta está operando detrás de un puerto abierto, información especialmente relevante para identificar software desactualizado.
- Motor de scripts NSE (Nmap Scripting Engine): conjunto extensible de scripts que automatizan comprobaciones específicas más allá de la simple detección de puertos, desde la enumeración de recursos compartidos hasta la verificación de configuraciones de autenticación débiles. Es el mecanismo empleado en este proyecto para confirmar, de forma dirigida, debilidades de configuración concretas (por ejemplo, acceso FTP anónimo) sobre los servicios detectados.

Esta herramienta se emplea de forma idéntica en ambos estados de la red, antes y después de la segmentación, con los mismos parámetros de escaneo, para garantizar que la comparación de resultados sea metodológicamente válida y no esté condicionada por diferencias en la técnica de auditoría empleada.

4.6 Entorno de emulación de redes

Un entorno de emulación de redes es una plataforma de virtualización especializada que permite construir topologías de red completas, con routers, firewalls, conmutadores y equipos finales, ejecutando el software real de cada dispositivo (no una simulación aproximada de su comportamiento), interconectados mediante enlaces virtuales que reproducen fielmente el comportamiento de una red física. Esto permite diseñar, desplegar y validar arquitecturas de red complejas sin necesidad de disponer del hardware físico correspondiente, resultando especialmente adecuado para el desarrollo y prueba de soluciones en un contexto académico como el de este proyecto.

La herramienta empleada es GNS3 (*Graphical Network Simulator 3*), una plataforma de código abierto que se apoya en QEMU/KVM para ejecutar imágenes reales de sistemas operativos y firmware de red. En este proyecto, OPNsense y los distintos nodos Linux, sobre un motor de emulación (la GNS3 VM) controlado desde un cliente gráfico independiente. Esta arquitectura cliente-servidor permite separar la interfaz de diseño de la topología (donde se construyen, configuran y cablean los nodos) del motor que realmente ejecuta cada dispositivo, que puede residir en la misma máquina o, como en el caso de este proyecto, en una máquina virtual dedicada (apartado 6.1). La elección de GNS3 como entorno de emulación, frente a otras alternativas existentes en el mercado, así como los criterios técnicos concretos que motivaron esta decisión para el equipo utilizado en este proyecto, se detallan en el apartado 6.1, donde se abordan también los recursos asignados y la configuración general del laboratorio desplegado.

5. Diseño de topología y arquitectura

Para poder adecuar la solución necesitamos ver desde donde se parte. Establecemos dos diagramas de red iniciales, el físico donde vemos las Zonas y otro lógico, donde establecemos las conexiones, rangos de red.

Como se detalló en el análisis de Ishikawa, Legal JBA y Asesores parte de una infraestructura completamente plana: un único conmutador sin VLANs, sin firewall por zonas y sin separación entre los equipos de las diferentes áreas, el servidor de expedientes y el Wi-Fi de invitados.

El objetivo de este apartado es traducir esa situación de partida, y el problema de exposición identificado, en un diseño de red concreto. Primero representando el estado actual y, seguido, la arquitectura segmentada a la que se quiere llegar aplicando principios Zero Trust acotados.

5.1 Diagramas de red

El primer diagrama de red que vemos representado es la siguiente **Figura 5.**

Diagrama de red físico, donde nos centramos en ver como se distribuyen las diferentes zonas físicamente y donde encontramos ubicados los elementos mas importantes.

También podemos ver cómo todos los puestos de trabajo de las cuatro áreas jurídicas, la zona de IT, el servidor de expedientes y el punto de acceso Wi-Fi cuelgan de los mismos conmutadores sin ningún elemento intermedio que filtre el tráfico.

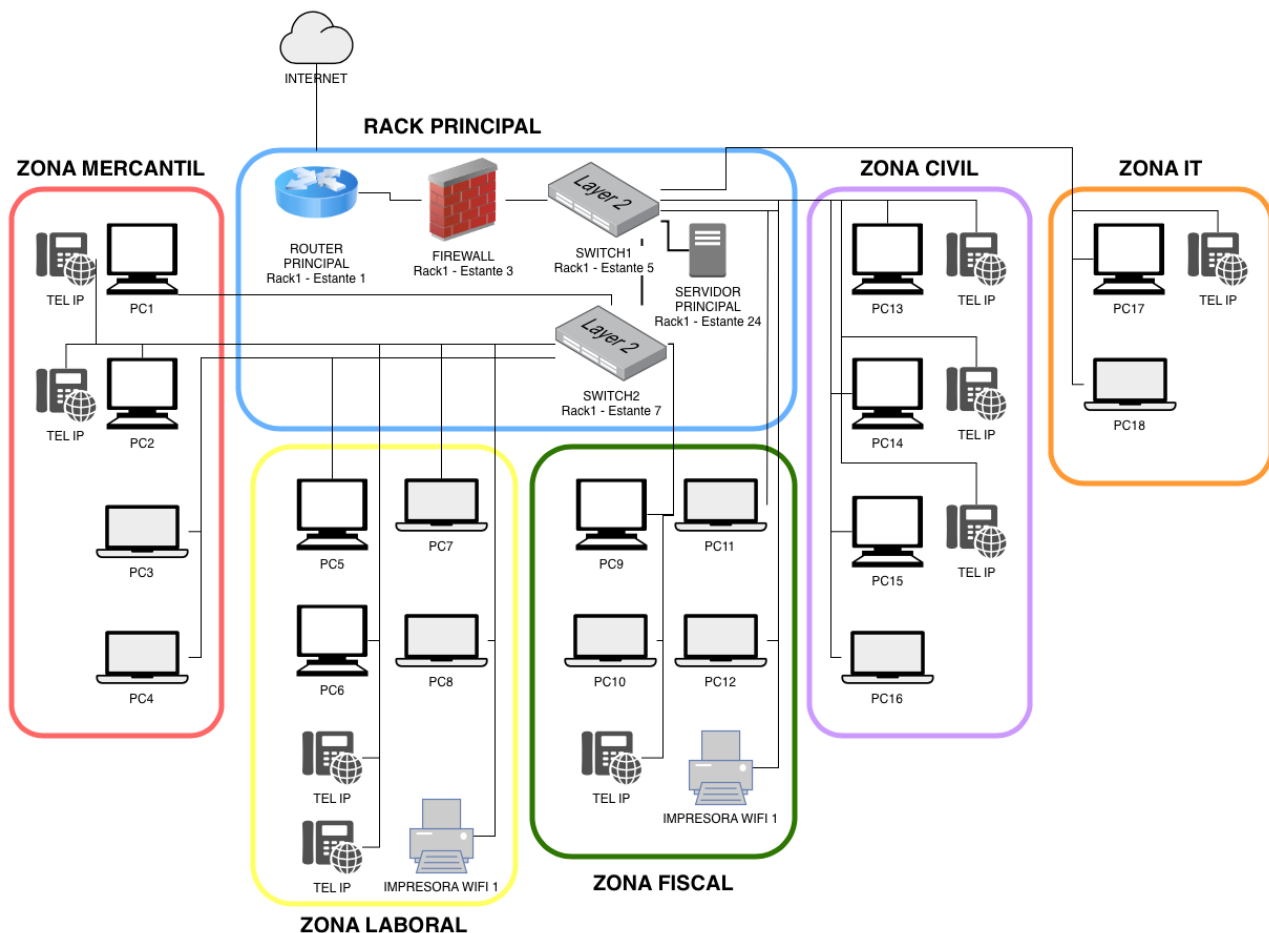


Figura 5. Diagrama red físico. *Elaboración propia.*

Para ver la situación inicial lógica, vemos la **Figura 6. Diagrama de red lógico inicial**, donde confirmamos que solo existe un único dominio de broadcast donde cualquier PC del despacho, electrónica crítica del rack principal, servidor de expedientes e incluso el Wi-Fi de invitados están en la misma red y pueden verse entre sí sin restricción alguna.

Esta es la causa raíz señalada en el diagrama de Ishikawa del Entregable 1: ausencia de segmentación, ausencia de firewall configurado y ausencia de monitorización, lo

que permite que cualquier equipo comprometido pueda moverse lateralmente hacia cualquier otro sin restricción.

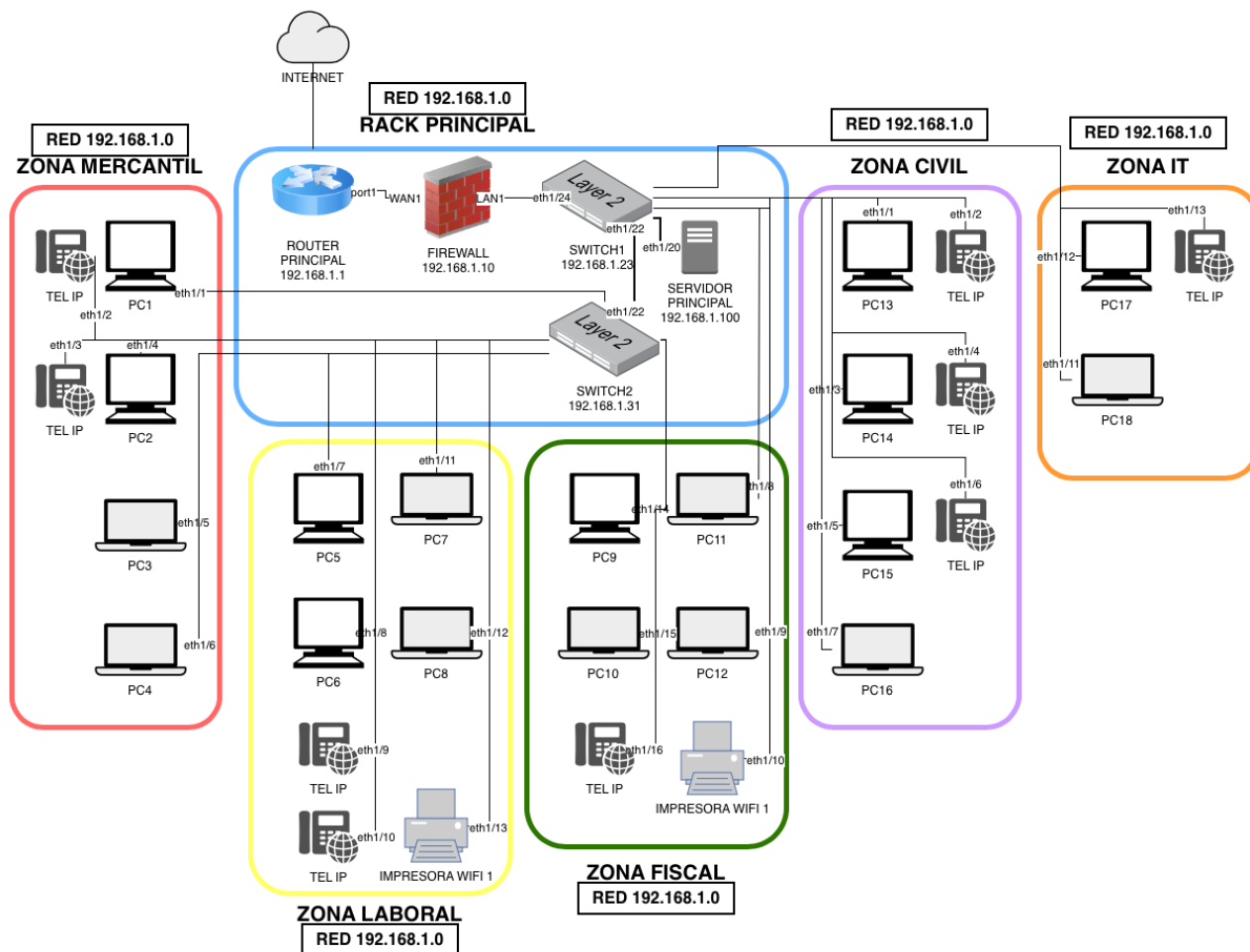


Figura 6. Diagrama red lógico inicial. *Elaboración propia.*

Por ultimo, observamos la Figura 7. Diagrama de red lógico objetivo, donde vemos la propuesta objetivo, con segmentación por VLANs, firewall por zonas, punto de entrada VPN y Suricata integrado en el perímetro.

5.2 Distribución de Vlan

Para pasar de la red plana inicial a la arquitectura segmentada se define una VLAN por cada zona funcional del despacho, siguiendo el principio de mínimo privilegio. Las cuatro áreas jurídicas (Mercantil, Laboral, Fiscal y Civil) quedan aisladas entre sí para respetar el secreto profesional y el criterio de necesidad de conocer, la zona de IT agrupa a los equipos del personal técnico, la VLAN de Gestión concentra los dispositivos de infraestructura (firewall, switch, router y servidor) para que su administración no sea accesible desde el resto de la red, y la VLAN de invitados aísla por completo el Wi-Fi ofrecido a visitas.

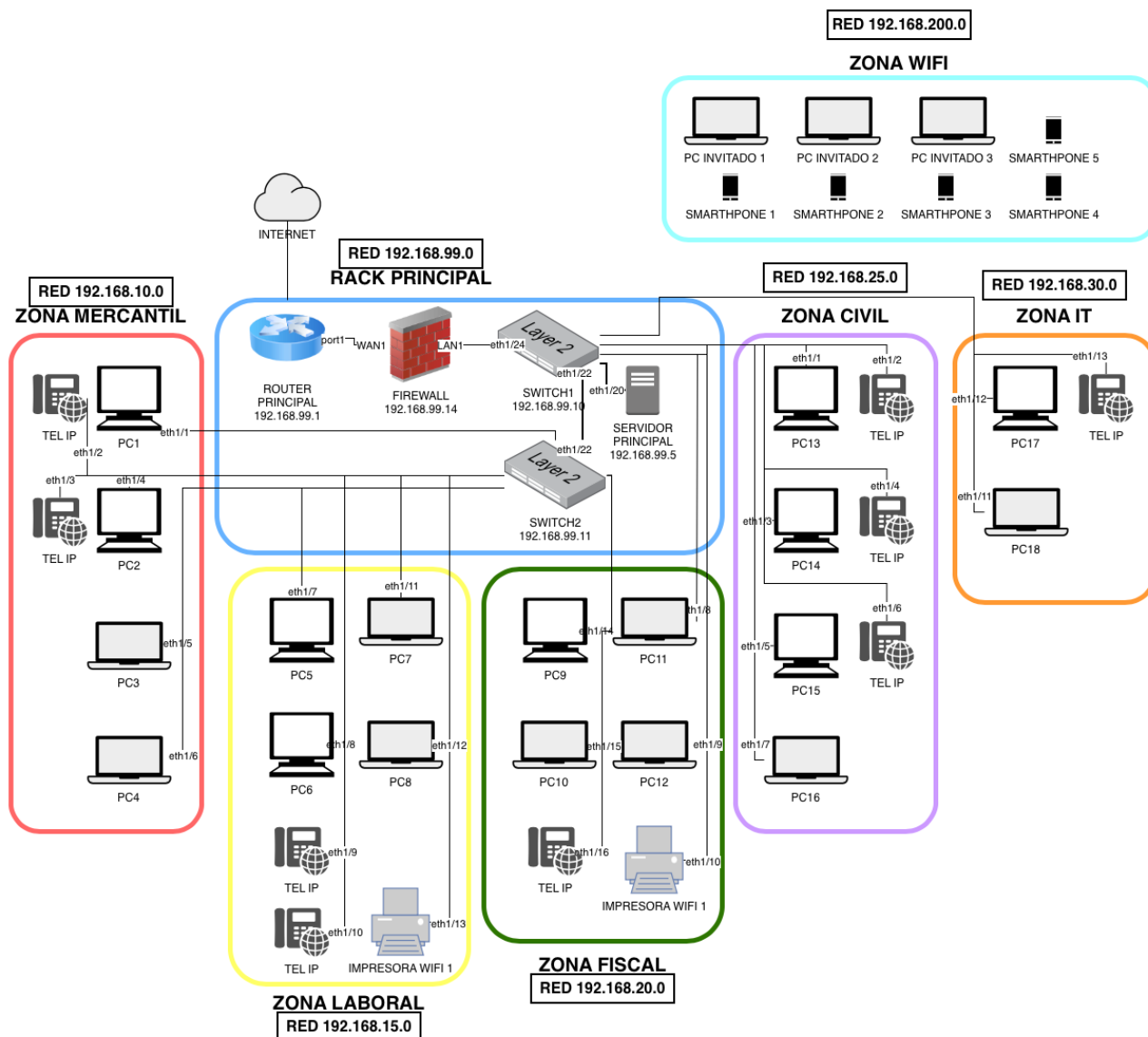


Figura 7. Diagrama red lógico objetivo. *Elaboración propia.*

La numeración deja huecos intencionados entre VLANs (10, 15, 20, 25, 30) para poder insertar nuevas VLANs en el futuro sin reordenar el esquema, y reserva el identificador 99 para la VLAN de gestión, siguiendo una convención habitual en redes empresariales.

VLAN ID	NOMBRE	DESCRIPCIÓN	Nº DISPOSITIVOS
99	GESTION	Vlan para gestión de dispositivos IT (FW, SW, Router, SRV)	5
10	MERCANTIL	Vlan para zona despacho Mercantil	6
15	LABORAL	Vlan para zona despacho Laboral	7
20	FISCAL	Vlan para zona despacho Fiscal	6

VLAN ID	NOMBRE	DESCRIPCIÓN	Nº DISPOSITIVOS
25	CIVIL	Vlan para zona despacho Civil	7
30	IT	Vlan para zona de IT	3
200	WIFI	Vlan para wifi invitados	-

5.3 Tabla de direccionamiento

El direccionamiento se dimensiona a partir del número de dispositivos de cada VLAN, dejando margen de crecimiento: las áreas jurídicas y la zona de IT usan una máscara /27 (30 hosts útiles), suficiente para los 6-7 dispositivos actuales de cada área jurídica y los 3 de IT, con holgura para incorporar equipos nuevos sin tener que reestructurar direccionamientos de VLAN.

La VLAN de gestión usa una /28 (14 hosts útiles), ajustada a los 5 dispositivos de infraestructura que aloja y adecuada a que su crecimiento no será tan alto como puede ser en los departamentos jurídicos.

Por último, la VLAN de invitados usa una /24 completa (254 hosts útiles) ya que el número de visitantes conectados es variable y no supone ningún riesgo adicional al estar totalmente aislada del resto de la red.

VLAN ID	SUBRED	GATEWAY	RANGO DISPONIBLE	Nº HOSTS ÚTILES
99	192.168.99.0/28	192.168.99.14	192.168.99.1-192.168.99.13	14
10	192.168.10.0/27	192.168.10.30	192.168.10.1-192.168.10.29	30
15	192.168.15.0/27	192.168.15.30	192.168.15.1-192.168.15.29	30
20	192.168.20.0/27	192.168.20.30	192.168.20.1-192.168.20.29	30
25	192.168.25.0/27	192.168.25.30	192.168.25.1-192.168.25.29	30
30	192.168.30.0/27	192.168.30.30	192.168.30.1-192.168.30.29	30
200	192.168.200.0/24	192.168.200.254	192.168.200.1 - 192.168.200.253	254

5.4 Matriz de comunicación entre zonas

Con las VLANs y sus rangos definidos, diseñamos la última pieza del esquema principal para establecer qué tráfico se permite entre ellas.

La siguiente tabla traduce el principio de mínimo privilegio a nivel de zona. Por defecto, todo el tráfico entre VLANs está bloqueado (X), y solo se habilita explícitamente lo que el despacho necesita para funcionar. Las cuatro áreas jurídicas

no pueden comunicarse entre sí bajo ningún concepto, reflejando el secreto profesional y el RGPD, un abogado de Mercantil no debe poder acceder a los equipos ni a los expedientes de Laboral, Fiscal o Civil, solo permitiendo servicios concretos para la comunicación entre los departamentos.

Cada área sí puede alcanzar la VLAN de Gestión, pero únicamente a "servicios concretos" (los puertos del servidor de expedientes), no a la totalidad de esa VLAN, que también aloja el firewall, el switch y el router. La VLAN de IT es la única con visibilidad SI hacia el resto de áreas, ya que su función es dar soporte técnico, pero tiene bloqueado el acceso a la red de invitados. La VLAN de invitados solo tiene salida a internet y no puede iniciar conexión hacia ninguna otra VLAN interna, cumpliendo el requisito RF03 del anterior punto 2.5. Estas mismas reglas son las que se convertirán en reglas de firewall concretas (protocolo, puerto, acción) en la fase de implementación principal (F6), y las que Suricata verificará que no se puedan saltar durante las pruebas de intrusión controladas (F8).

	GESTION	MERCANTIL	LABORAL	FISCAL	CIVIL	IT	WIFI INVITADOS	INTERNET
GESTION	-	X	X	X	X	X	X	NO (Servicios concretos)
MERCANTIL	Servicios concretos	-	X	X	X	X	X	SI
LABORAL	Servicios concretos	X	-	X	X	X	X	SI
FISCAL	Servicios concretos	X	X	-	X	X	X	SI
CIVIL	Servicios concretos	X	X	X	-	X	X	SI
IT	SI	SI	SI	SI	SI	-	X	SI
WIFI INVITADOS	X	X	X	X	X	X	-	SI

5.5 Tabla de reglas

Con la anterior matriz de comunicación definimos qué está permitido en cada zona, con la siguiente tabla buscamos traducir y facilitar las reglas concretas que se deberán crear, en el formato en que se implementarán en pfSense/OPNsense (origen, destino, protocolo y puerto, acción).

En los Firewalls el orden es importante, se evalúan las reglas de arriba hacia abajo y aplica la primera que coincide, por lo que las reglas de permiso (ALLOW) más específicas se sitúan antes que las reglas de bloqueo (DENY) más generales, y la última regla (R12) es un deny-all implícito que cierra cualquier tráfico no contemplado explícitamente, materializando el principio Zero Trust de "denegar por defecto".

Regla	Origen	Destino	Protocolo / Puerto	Acción	Justificación
R01	Mercantil, Laboral, Fiscal, Civil (VLAN 10/15/20/25)	Servidor de expedientes (VLAN Gestión)	TCP 445 (SMB), TCP 443 (HTTPS)	ALLOW	Acceso de cada área a su gestor documental, sin acceso al resto de la VLAN Gestión
R02	Mercantil, Laboral, Fiscal, Civil (VLAN 10/15/20/25)	Resto de VLAN Gestión (firewall, switches, router)	Cualquiera	DENY	Impide administrar la infraestructura desde puestos de usuario
R03	Mercantil, Laboral, Fiscal, Civil, entre sí (VLAN 10/15/20/25)	Mercantil, Laboral, Fiscal, Civil, entre sí	Cualquiera	DENY	Aislamiento total entre áreas jurídicas (secreto profesional, RGPD)
R04	Mercantil, Laboral, Fiscal, Civil, IT (VLAN 10/15/20/25/30)	Internet	TCP 80, TCP 443, UDP 53	ALLOW	Navegación web y resolución DNS
R05	IT (VLAN 30)	Mercantil, Laboral, Fiscal, Civil (VLAN 10/15/20/25)	TCP 3389 (RDP), TCP 22 (SSH), ICMP	ALLOW	Soporte técnico y diagnóstico remoto a cualquier puesto
R06	IT (VLAN 30)	Gestión (VLAN 99)	TCP 443 (admin web), TCP 22 (SSH), UDP 161 (SNMP)	ALLOW	Administración de firewall, switches y servidor
R07	IT (VLAN 30)	WiFi invitados (VLAN 200)	Cualquiera	DENY	IT no necesita acceso a la red de invitados

R08	Gestión (VLAN 99)	Mercantil, Laboral, Fiscal, Civil, IT, WiFi invitados (VLAN 10/15/20/25/30/200)	Cualquiera	DENY	La infraestructura no inicia conexiones hacia las VLANs de usuario, solo responde
R09	Gestión (VLAN 99)	Internet	UDP 123 (NTP), UDP/TCP 53 (DNS), TCP 443 (HTTPS)	ALLOW	Hora, resolución de nombres y actualización de firmas de Suricata y paquetes del sistema
R10	WiFi invitados (VLAN 200)	Internet	TCP 80, TCP 443, UDP 53	ALLOW	Acceso a internet para las visitas
R11	WiFi invitados (VLAN 200)	Cualquier VLAN interna	Cualquiera	DENY	Aislamiento total de la red de invitados (RF03)
R12	Cualquier origen	Cualquier destino	Cualquiera	DENY	Regla de cierre implícita: todo lo no permitido explícitamente queda bloqueado (Zero Trust)

Los usuarios que se conecten a través de la VPN de acceso remoto reciben las mismas reglas que su VLAN de origen: el firewall les asigna una dirección dentro del túnel y aplica sobre ese tráfico el mismo conjunto de reglas que si estuvieran físicamente en su despacho, en lugar de crear una zona de confianza aparte.

Suricata, por su parte, no participa en esta tabla porque funciona en modo de detección (IDS) ya que, no permite ni bloquea tráfico, genera alertas cuando detecta un intento de saltarse estas reglas, que se validarán en futuras pruebas de intrusión de la fase F8.

6. Entorno laboratorio

Una vez definida la arquitectura objetivo. VLANs, direccionamiento, matriz de comunicación y reglas de firewall, el siguiente paso consiste en trasladar ese diseño a un entorno de laboratorio virtualizado que permita validarlo de forma controlada, sin necesidad de desplegar sobre infraestructura real como se estipula en el requisito RNF02.

Esta sección documenta el entorno de virtualización empleado, los appliances utilizados que ayudan a representar cada elemento de la arquitectura, la topología montada y la configuración base sobre la que se ejecutará posteriormente la auditoría inicial (apartado 6) y la implementación de la segmentación (apartado 7).

6.1 Entorno de virtualización

El laboratorio se ha desplegado sobre un equipo Mac con procesador Intel, lo que permite ejecutar GNS3 con aceleración por hardware (Intel VT-x) de forma nativa, sin las limitaciones que presenta actualmente la arquitectura Apple Silicon (M1-M4) para la emulación de sistemas x86 como pfSense/OPNsense.

Como hipervisor se ha utilizado VMware Fusion, de uso gratuito para fines personales, sobre el cual se ha desplegado la VM GNS3 oficial, esta es una máquina virtual Ubuntu que actúa como motor de emulación (QEMU/KVM) para todos los nodos del laboratorio.

El cliente GNS3 GUI se instala directamente en el SO del equipo, en este caso macOS y se conecta a la VM GNS3 para construir y controlar la topología.

Se descartó el uso de EVE-NG como alternativa al no existir una versión nativa para macOS, requeriría igualmente desplegar una máquina virtual Linux como capa intermedia, sin aportar ninguna ventaja adicional respecto a GNS3 en este escenario y añadiendo complejidad innecesaria.

Equipo anfitrión utilizado para la virtualización:

- MacBook Pro, procesador Intel, 8 GB de RAM total.

Recursos asignados:

- Dado el límite de RAM del equipo anfitrión, se ha repartido la memoria de forma ajustada entre los distintos componentes, tal como recoge la Tabla X:

VM / Nodo	vCPU	RAM	Descripción
VM GNS3	3	5GB	VM que gestiona los recursos dados a los diferentes Nodos de GNS3
OPNSense	1	1GB	
Servidor Expedientes	2	1GB	
Equipo simulado	2	1GB	
Equipo auditoria	2	1GB	
VPCS	-	-	

Para que los appliances basados en QEMU (OPNsense, Debian) puedan beneficiarse de aceleración KVM y además, evitar bloqueos aparentes del sistema operativo invitado por la saturación de CPU, ha sido necesario habilitar explícitamente la virtualización anidada en la configuración de la GNS3 VM dentro de VMware Fusion (opción *"Enable hypervisor applications in this virtual machine"*), también y como se ha comentado en la anterior tabla, para que los nodos utilizados tengan los recursos suficientes se ha aumentado tanto el número de procesos como la Memoria RAM que utiliza la VM GNS3.

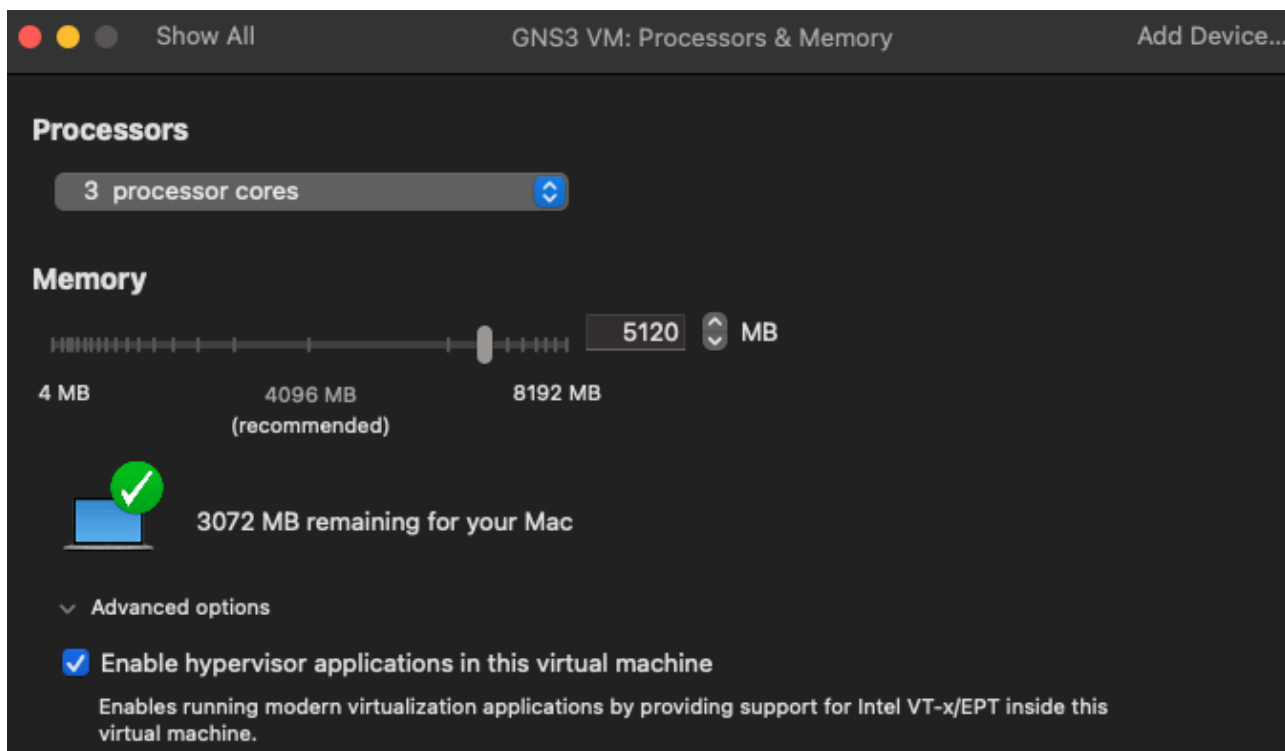


Imagen 1. Procesador, memoria y Enable hypervisor Applications in this virtual machine

A nivel de red, la VM GNS3 utiliza el adaptador NAT por defecto de VMware Fusion para su propia salida a internet (necesaria para la descarga de appliances y actualizaciones), mientras que la topología interna del laboratorio se construye sobre redes completamente aisladas dentro de GNS3, sin exposición a la red física del equipo anfitrión.

6.2 Appliances utilizados

Para representar cada elemento de la arquitectura diseñada, se han utilizado los siguientes appliances, todos ellos software libre obtenidos de fuentes oficiales

Elemento	Appliance	Rol
Firewall perimetral	OPNSense v26.1	Router, firewall, NAT, DHCP, futura segmentación VLAN
2 Switches	Switch nativo GNS3	Conmutación L2 y soporte 802.1Q para VLANs
Servidor Expedientes	Debian 12.6, imagen descargada desde GNS3	Función general de servidor expedientes. Exposición de puertos SSH, FTP, Samba
Endpoint Windows simulado	Debian 12.6, imagen descargada desde GNS3	Simulación de equipo Windows con puertos RDP y SMB operativos

Elemento	Appliance	Rol
Endpoint Auditoria	Debian 12.6, imagen descargada desde GNS3	Equipo principal para realizar escaneos pre/post
Endpoints de zona	VPCS	Representación muy básica de equipos por zona

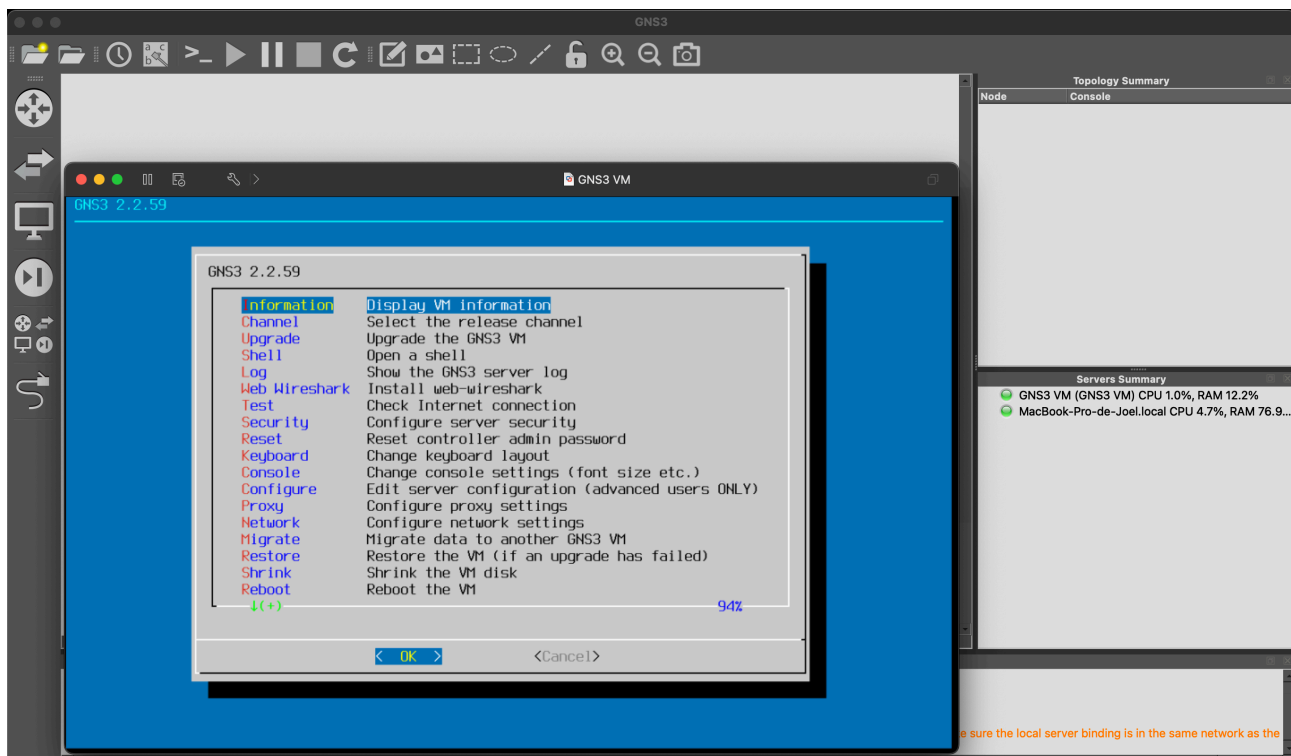


Imagen 2. Entorno de virtualización operativo: GNS3 VM en ejecución dentro de VMware Fusion y cliente GNS3 conectado correctamente al servidor.

Aclaración sobre los nodos VPCS:

La mayoría de los puestos de usuario se han representado mediante VPCS (*Virtual PC Simulator*), se trata de un tipo de nodo nativo de GNS3 que implementa únicamente una pila IP mínima, sin sistema operativo completo ni servicios en escucha. Su bajo consumo de recursos lo hace idóneo para representar puestos de trabajo cuando el objetivo es validar conectividad y aplicación de reglas de red, sin necesidad de auditar servicios sobre ellos.

Aclaración sobre el equipo "Windows simulado":

Para disponer de al menos un endpoint con el perfil de puertos característico de un cliente Windows corporativo (Escritorio Remoto, recursos compartidos SMB) de cara a la auditoría del apartado 6, se valoró la incorporación de un sistema Windows real. Se descartó utilizar imágenes de evaluación oficiales de Windows 10/11, aunque gratuitas durante 90 días, requieren recursos adicionales y una necesidad de configuración que no es necesaria para el objetivo a validar.

Como alternativa, se ha optado por instalar sobre una imagen Debian ligera los servicios xrdp (puerto 3389) y Samba (puertos 139/445), reproduciendo la misma

huella de red que expondría un cliente Windows real ante un escaneo de puertos, sin el coste de recursos de una instalación completa. Esta simplificación no afecta a la validez de los resultados de auditoría, dado que estos se basan en los puertos y servicios expuestos, no en el sistema operativo subyacente.

6.3 Topología del laboratorio

La siguiente Figura 9 muestra la topología montada en GNS3, replica la red plana inicial descrita en el anterior apartado 4, todos en el mismo segmento 192.168.1.0/24, sin ninguna segmentación aplicada todavía.

Esta configuración constituye el punto de partida sobre el que se ejecuta la auditoría inicial (apartado 6) y que posteriormente se transformará en la arquitectura segmentada (apartado 7).

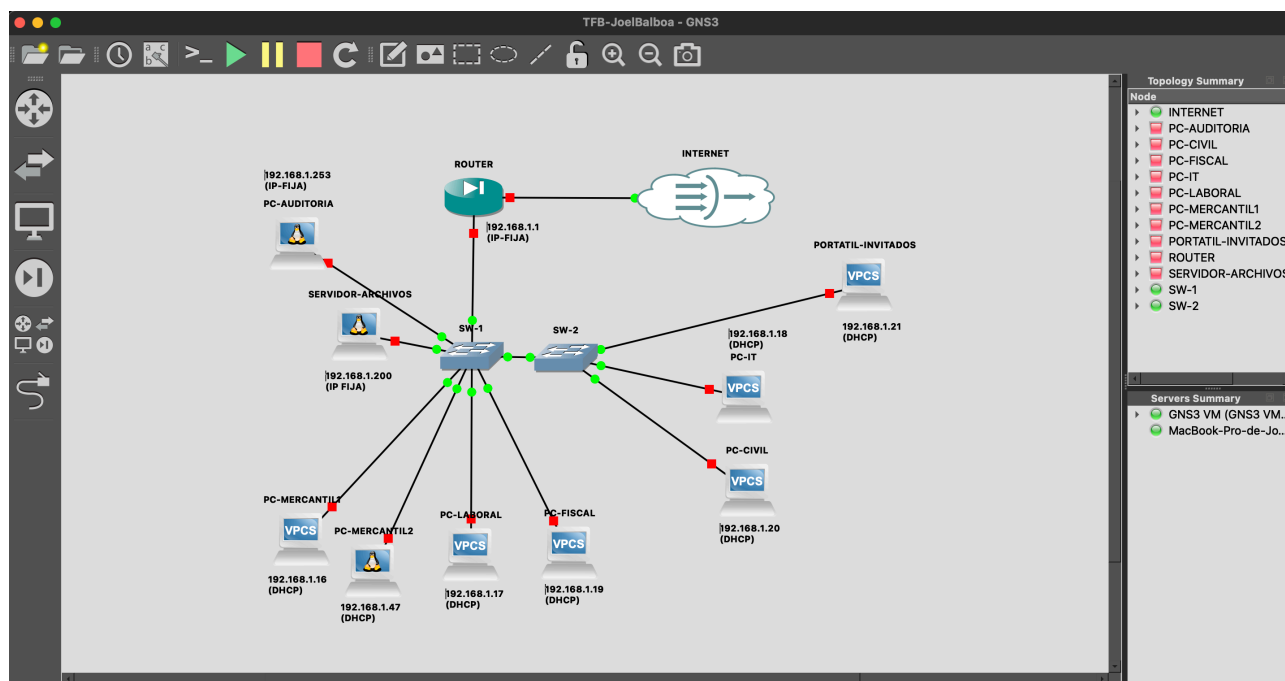


Figura 9. Topología de red plana en GNS3, réplica de la situación inicial descrita en el apartado 4.

Cabe señalar que, si bien en los diagramas de red del apartado 4 se representan entre 3 y 7 dispositivos por cada área jurídica (Figuras 5-7), la topología virtualizada en el laboratorio incluye un único equipo representativo por zona. Esta decisión responde tanto a una limitación de recursos del equipo anfitrión (apartado 5.1) como a un criterio de optimización. A efectos de validar la segmentación por VLANs, las reglas de firewall y el comportamiento de la auditoría de seguridad, el resultado de las pruebas de conectividad y escaneo es idéntico independientemente de si una VLAN contiene uno o siete equipos, ya que todos los dispositivos de una misma zona comparten el mismo tratamiento a nivel de red (misma VLAN, misma subred, mismas reglas de firewall aplicadas). Un único nodo por zona es, por tanto, igualmente válido para demostrar y auditar la solución, sin que ello afecte a la validez de los resultados obtenidos ni a las conclusiones del proyecto.

6.4 Configuración base y validación del entorno

Sobre esta topología se ha configurado OPNsense como puerta de enlace de la red (192.168.1.1/24) y servidor DHCP activo para el rango 192.168.1.10-199. Cada uno de los nodos con sistema operativo real (servidor de expedientes, PC-Windows-simulado) ha sido configurado con los servicios expuestos en la Tabla Y, deliberadamente sin políticas de acceso, replicando las debilidades identificadas en el diagrama de Ishikawa (ausencia de políticas de seguridad, contraseñas y configuraciones por defecto).

El correcto funcionamiento del entorno se valida mediante conectividad extremo a extremo, cada equipo alcanza su puerta de enlace y, a través de OPNsense, la salida a internet. Se valida que, los servicios configurados en los nodos objetivo responden correctamente a nivel local antes de ser sometidos a la auditoría inicial del siguiente apartado.

```
[debian@debian:~$ ping 192.168.1.1
PING 192.168.1.1 (192.168.1.1) 56(84) bytes of data.
64 bytes from 192.168.1.1: icmp_seq=1 ttl=64 time=2.32 ms
64 bytes from 192.168.1.1: icmp_seq=2 ttl=64 time=4.62 ms
64 bytes from 192.168.1.1: icmp_seq=3 ttl=64 time=4.15 ms
64 bytes from 192.168.1.1: icmp_seq=4 ttl=64 time=3.99 ms
64 bytes from 192.168.1.1: icmp_seq=5 ttl=64 time=1.88 ms
^X^[[A64 bytes from 192.168.1.1: icmp_seq=6 ttl=64 time=4.00 ms
^X64 bytes from 192.168.1.1: icmp_seq=7 ttl=64 time=6.43 ms
64 bytes from 192.168.1.1: icmp_seq=8 ttl=64 time=5.95 ms
^Z
[2]+  Stopped                  ping 192.168.1.1
[debian@debian:~$ ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=126 time=34.3 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=126 time=37.2 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=126 time=32.0 ms
64 bytes from 8.8.8.8: icmp_seq=4 ttl=126 time=26.7 ms
^Z
[3]+  Stopped                  ping 8.8.8.8
debian@debian:~$
```

Figura 10. Verificación de conectividad hacia puerta enlace e internet

Es importante subrayar que estas configuraciones inseguras han sido introducidas de forma deliberada y controlada con el único propósito de disponer de un entorno de pruebas auditable y con servicios lo mas cercanos a entornos reales, siendo únicamente de interés validar la visibilidad de puertos y servicios desde equipos en la misma red.

7. Auditoría inicial — situación PRE

Con el entorno de laboratorio operativo (anterior Apartado 6), se procede a ejecutar la auditoría de exposición sobre la red plana inicial con el objetivo de establecer una línea base cuantificable (puertos accesibles, servicios expuestos y debilidades de configuración) que permita, tras la implementación de la segmentación (apartado 7), evaluar objetivamente la mejora de seguridad conseguida (RNF04, KR1, KR4).

Esta misma metodología y estos mismos comandos se repetirán de forma idéntica sobre la red ya segmentada, garantizando que la comparación se realice en igualdad de condiciones.

7.1 Metodología y herramientas

La auditoría se ejecuta desde un nodo dedicado dentro de la propia red del laboratorio (PC-Auditoria, 192.168.1.253), en lugar de desde el equipo anfitrión, replicando al máximo el escenario de un atacante que ya ha obtenido acceso a la red interna o al punto de acceso Wi-Fi de invitados, siendo un planteamiento más realista que auditar desde fuera de la topología.

Se emplea Nmap como herramienta de descubrimiento y escaneo de puertos, en tres fases sucesivas y con los mismos parámetros que se reutilizarán en la siguiente auditoría POST.

1. Descubrimiento de todos los hosts vivos en toda la red 192.168.1.0

```
sudo nmap -sn 192.168.1.0/24
```

2. Descubrimiento de todos los puertos abiertos, servicios y scripts generales.

```
sudo nmap -sV -sC -p- -Pn -T4 IP-HOST
```

3. Forzar scripts de vulnerabilidades específicos para los diferentes puertos obtenidos y los servicios expuestos.

```
sudo nmap --script [...] -p [puertos expuestos anteriormente] IP-HOST
```

El escaneo se ejecuta con privilegios de root (sudo), necesario para que Nmap pueda realizar descubrimiento por ARP en lugar de depender de conexiones TCP, y con el parámetro -Pn para asegurar la comparabilidad futura, dado que tras la segmentación es probable que las reglas de firewall bloqueen el tráfico ICMP entre zonas.

7.2 Descubrimiento de hosts

El primer escaneo de descubrimiento (nmap -sn) sobre la red 192.168.1.0/24 identifica los siguientes hosts activos:

IP	Nodo	Descripción
192.168.1.1	OPNSense	Router
192.168.1.16	VPCS	PC Mercantil 1
192.168.1.17	VPCS	PC Laboral
192.168.1.18	VPCS	PC IT
192.168.1.19	VPCS	PC Fiscal
192.168.1.20	VPCS	PC Civil
192.168.1.21	VPCS	PC Invitados
192.168.1.47	Debian	PC Mercantil 2
192.168.1.250	Debian	Servidor expedientes
192.168.1.253	Debian	PC auditoria

```
(debian@debian:~/auditorias$ sudo nmap -sn 192.168.1.0/24 -oA /home/debian/auditorias/pre/1_descubrimiento
Starting Nmap 7.93 ( https://nmap.org ) at 2026-07-21 14:55 UTC
Nmap scan report for OPNsense.internal (192.168.1.1)
Host is up (0.097s latency).
MAC Address: 0C:6C:79:B8:00:00 (Unknown)
Nmap scan report for 192.168.1.16
Host is up (0.044s latency).
MAC Address: 00:50:79:66:68:06 (Private)
Nmap scan report for 192.168.1.17
Host is up (0.038s latency).
MAC Address: 00:50:79:66:68:07 (Private)
Nmap scan report for 192.168.1.18
Host is up (0.034s latency).
MAC Address: 00:50:79:66:68:08 (Private)
Nmap scan report for 192.168.1.19
Host is up (0.034s latency).
MAC Address: 00:50:79:66:68:09 (Private)
Nmap scan report for 192.168.1.20
Host is up (0.024s latency).
MAC Address: 00:50:79:66:68:0A (Private)
Nmap scan report for 192.168.1.21
Host is up (0.025s latency).
MAC Address: 00:50:79:66:68:0B (Private)
Nmap scan report for 192.168.1.47
Host is up (0.16s latency).
MAC Address: 0C:86:53:CA:00:00 (Unknown)
Nmap scan report for 192.168.1.250
Host is up (0.19s latency).
MAC Address: 0C:2A:3A:28:00:00 (Unknown)
Nmap scan report for 192.168.1.253
Host is up.
Nmap done: 256 IP addresses (10 hosts up) scanned in 8.49 seconds
debian@debian:~/auditorias$
```

Figura 10. Resultado del escaneo general sobre la red 192.168.1.0/24

Todos los hosts configurados en el laboratorio resultan alcanzables entre sí sin ninguna restricción, confirmando la ausencia de segmentación descrita en el apartado 4 y viendo que cualquier equipo de la red, incluido el que representa la zona de invitados, puede iniciar una conexión hacia cualquier otro.

7.3 Puertos y servicios con debilidades detectados

Una vez obtenemos el listado de equipos activos en la red, realizamos un escaneo completo de puertos y servicios (-sV -sC -p- -Pn -T4). Esto se realizará sobre los hosts que creemos que nos devolverá algún puerto o servicio disponible.

Los equipos representados mediante VPCS no exponen ningún puerto, al tratarse únicamente de una pila IP mínima sin servicios en escucha, como se ha comentado anteriormente, su relevancia en esta auditoría es únicamente la de confirmar alcanzabilidad, no la de aportar hallazgos de puertos o servicios activos.

Equipo	Puerto	Servicio
192.168.1.47	22	OpenSSH 9.2p1
192.168.1.47	139	Samba smbd 4.6.2
192.168.1.47	445	Samba smbd 4.6.2
192.168.1.47	3389	Xrdp
192.168.1.250	21	Vsftpd 3.0.3
192.168.1.250	22	OpenSSH 9.2p1
192.168.1.250	139	Samba smbd 4.6.2
192.168.1.250	445	Samba smbd 4.6.2

```

joelbalboa — PC-AUDITORIA — telnet 192.168.254.129 5015 — 110x26
debian@debian:~$ sudo nmap -sV -sC -p- -Pn -T4 192.168.1.250
Starting Nmap 7.93 ( https://nmap.org ) at 2026-07-22 12:11 UTC
Nmap scan report for 192.168.1.250
Host is up (0.0035s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.3
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|ftp-syst:
|  STAT:
|  FTP server status:
|    Connected to ::ffff:192.168.1.253
|    Logged in as ftp
|    TYPE: ASCII
|    No session bandwidth limit
|    Session timeout in seconds is 300
|    Control connection is plain text
|    Data connections will be plain text
|    At session startup, client count was 2
|    vsFTPD 3.0.3 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 9.2p1 Debian 2+deb12u10 (protocol 2.0)
|ssh-hostkey:
|  256 269ea87447695c6d455a4d4ad179919d (ECDSA)
|_ 256 11d8806a5abee2230ef1a0f94972021a (ED25519)
139/tcp   open  netbios-ssn Samba smbd 4.6.2

```

Figura 10. Resultado del escaneo de puertos y versión de servicio sobre el Servidor de expedientes (192.168.1.250)

Además de la simple detección de puertos, se ha intentado mediante scripts NSE específicos, confirmar las vulnerabilidades encontradas anteriormente.

Dado que algunos scripts NSE no devuelven una salida suficientemente clara (por ejemplo, la enumeración de recursos Samba requiere una negociación adicional que no siempre se completa vía script), se ha optado por realizar verificaciones mediante un acceso manual básico a los servicios expuestos, confirmando de forma directa su exposición real.

Para ello se han utilizado los siguientes comandos:

1. Verificar acceso FTP

```
ftp IP-HOST
```

2. Verificar acceso SSH

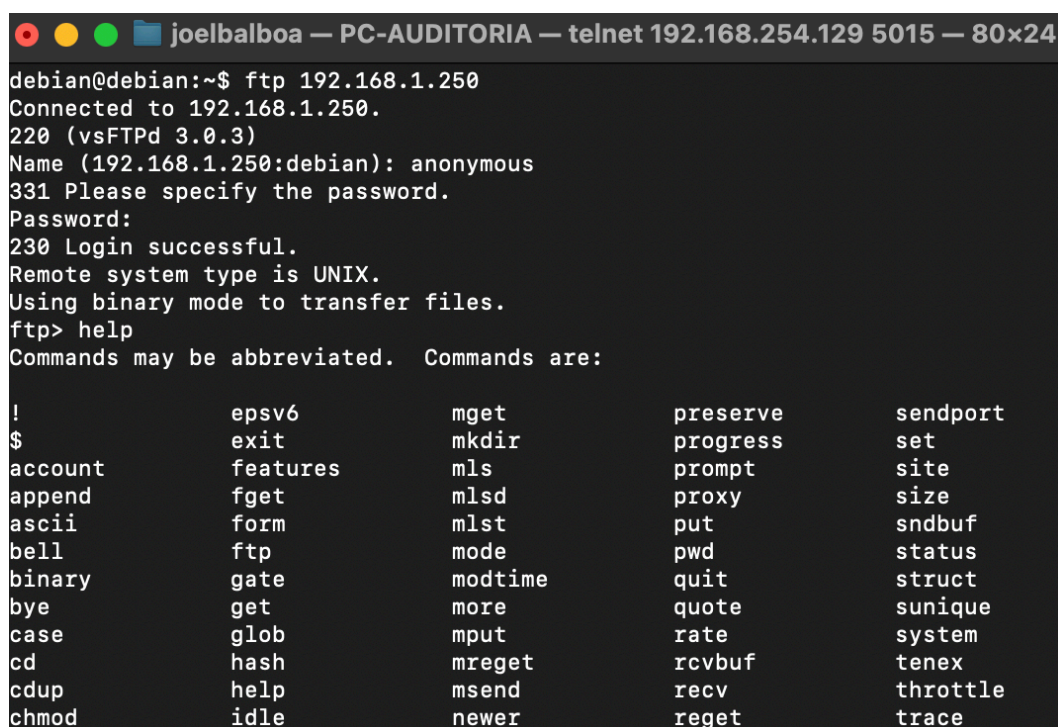
```
ssh root@IP-HOST
```

3. Ver recursos SAMBA públicos

```
smbclient -L //IP-HOST -N  
smbclient //IP-HOST/carpeta -N
```

4. Revisar servicio RDP

```
nmap --script rdp-ntlm-info -p 3389 IP-HOST
```



```
joelbalboa — PC-AUDITORIA — telnet 192.168.254.129 5015 — 80x24
debian@debian:~$ ftp 192.168.1.250
Connected to 192.168.1.250.
220 (vsFTPd 3.0.3)
Name (192.168.1.250:debian): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> help
Commands may be abbreviated.  Commands are:

!                epsv6             mget             preserve         sendport
$                exit              mkdir            progress         set
account          features          mls              prompt           site
append           fget             mlsl             proxy            size
ascii            form             mlst             put              sndbuf
bell             ftp              mode             pwd              status
binary           gate             modtime          quit             struct
bye              get              more             quote            sunique
case             glob             mput             rate             system
cd               hash             mreget           rcvbuf           tenex
cdup             help             msend           recv             throttle
chmod            idle             newer            reget            trace
```

Figura 10. Acceso FTP anónimo y listado del recurso SMB con autenticación anonymous sobre el servidor de expedientes (192.168.1.250)

Como punto final a destacar de estos escaneos y pruebas de acceso, el objetivo no es otro mas que dar visibilidad del posible alcance negativo que se puede dar contra una red de estas características, totalmente plana, sin segmentación ni seguridad alguna entre los diferentes accesos y con recursos que muchas veces no están actualizados y que facilitan la intrusión a sistemas privados y con información privada.

En los anexos xxx se añaden la totalidad de los diferentes escaneos realizados, mostrando el escaneo de toda la red 192.168.1.0/24, un VPCS, el Endpoint Windows simulado y el Endpoint Servidor Expedientes. También evidencias de los accesos FTP, SSH, SAMBA.

7.4 Línea base para la comparativa

A partir de los resultados obtenidos en los anteriores apartados 7.2 y 7.3, se establece una línea base numérica que servirá de referencia directa para la tabla comparativa pre/post exigida por el KR4 una vez implementada la segmentación (apartado 8).

Métrica utilizada	Valores PRE
Hosts alcanzables desde equipo Auditoria (Red 192.168.1.0/24)	100% (10 de 10)
Total de puertos abiertos descubiertos	8
Accesos a servicios comprometidos	4 (FTP, SMB, SSH, RDP)
Alertas generadas	0

Estos valores constituyen el punto de comparación directo para la tabla comparativa pre/post del KR4.

Tras la segmentación, se espera una reducción de hosts alcanzables, cero conectividad desde la VLAN de invitados hacia el resto y una reducción de los puertos accesibles entre zonas no autorizadas, manteniendo el mismo número de puertos abiertos localmente en cada servidor, con la segmentación no buscamos cerrar o eliminar los servicios en sí, sino generar un control de accesibilidad a estos.

X1. Bibliografía de referencia

Alvarez Cedillo, J. A., y Ibarra Balderas, V. M. (2012). El uso del diagrama causa-efecto en el análisis de casos. *Revista del Instituto Mexicano de Contadores Públicos*. <https://www.redalyc.org/pdf/270/27018888005.pdf>

Universidad Internacional de La Rioja (UNIR). (2025, 12 de noviembre). Diagrama de Ishikawa: qué es y cómo aplicarlo en la resolución de problemas. <https://www.unir.net/revista/empresa/que-es-diagrama-de-ishikawa/>

Sánchez Huerta, D. (2020). Análisis DAFO o FODA: El mejor y más completo estudio con 9 ejemplos prácticos. Bubok Publishing. ISBN: 978-84-685-5151-3.
<https://www.studocu.com/es/document/universidad-del-pais-vasco/gestion-de-empresas-iii-direccion-estrategica/sanchez-huerta-d-2020-analisis-dafo-o-foda-barcelona-editorial-bubok/94613940>

Asana. (2026). *SWOT analysis: Examples and templates*. <https://asana.com/es/resources/swot-analysis>

BBVA Innovation Center. (2015). Design Thinking [eBook gratuito en español]. BBVA. https://www.bbva.com/wp-content/uploads/2017/10/ebook-cibbva-design-thinking_es_1.pdf

Brown, T. (2008). Design Thinking. *Harvard Business Review*, 86(6), 84–92.
<https://www.educaciontrespuntocero.com/libros/libros-sobre-design-thinking/>

Asana. (2026, 2 de abril). *Design Thinking Process: Stages, tips, and examples*. <https://asana.com/es/resources/design-thinking-process>

Doran, G. T. (1981). There's a S.M.A.R.T. Way to Write Management's Goals and Objectives. *Management Review*, 70(11), 35–36.
<https://www.scirp.org/reference/ReferencesPapers?ReferenceID=1459599>

Canva. (s. f.). Diagrama de Gantt: qué es y cómo hacerlo. https://www.canva.com/es_es/pizarra-online/diagrama-gantt/

Atlassian. (s. f.). ¿Qué es un diagrama de Gantt? <https://www.atlassian.com/es/agile/project-management/gantt-chart>

Lucid Software Inc. (s. f.). ¿Qué es un diagrama PERT? <https://www.lucidchart.com/pages/es/que-es-un-diagrama-de-pert>

Salesforce. (s. f.). Diagrama de PERT: qué es, cómo funciona y cómo elaborarlo. <https://www.salesforce.com/mx/blog/diagrama-de-pert/>

Chandramouli, R., Butcher, M., y Chetal, S. (2023). *A Zero Trust Architecture Model for Access Control in Cloud-Native Applications in Multi-Cloud Environments* (NIST Special Publication 800-207A). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-207A>

National Institute of Standards and Technology. (2020). *Zero Trust Architecture* (NIST Special Publication 800-207). <https://doi.org/10.6028/NIST.SP.800-207>

GNS3 Project. (s.f.). *GNS3 Documentation: The official guide and reference for GNS3*. Recuperado el 26 de junio de 2026, de <https://docs.gns3.com>

EVE-NG Ltd. (s.f.). *EVE-NG: The first clientless multivendor network emulation software*. Recuperado el 26 de junio de 2026, de <https://www.eve-ng.net>

Netgate. (s.f.). *Virtual LANs (VLANs) — pfSense Documentation*. Recuperado el 26 de junio de 2026, de <https://docs.netgate.com/pfsense/en/latest/vlan/index.html>

OPNsense Project. (s.f.). *VLAN and LAGG Setup — OPNsense Documentation*. Recuperado el 26 de junio de 2026, de https://docs.opnsense.org/manual/how-tos/vlan_and_lagg.html

Open Information Security Foundation (OISF). (s.f.). *What is Suricata — Suricata Documentation*. Recuperado el 26 de junio de 2026, de <https://docs.suricata.io/en/latest/what-is-suricata.html>

Open Information Security Foundation (OISF). (s.f.). *Quickstart guide — Suricata Documentation*. Recuperado el 26 de junio de 2026, de <https://docs.suricata.io/en/latest/quickstart.html>

Lyon, G. (2009). *Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning*. Nmap Project. ISBN: 978-0-9799587-1-7. <https://nmap.org/book/>

CCNA desde Cero. (s.f.). *Diagrama de topología de red: qué es y cómo hacer uno paso a paso.* Recuperado el 22 de julio de 2026, de <https://ccnadesdecero.es/representacion-red-diagrama-de-topologia/>

AprendaRedes. (s.f.). *Calculadora IP / IP Subnetting.* Recuperado el 22 de julio de 2026, de <https://www.aprendaredes.com/cgi-bin/ipcalc/ipcalc.cgi>

GNS3. (s.f.). *GNS3: The Network Simulation Software.* Recuperado el 22 de julio de 2026, de <https://www.gns3.com/>

CCNA desde Cero. (s.f.). *¿Qué es GNS3? Para qué sirve y cómo instalarlo.* Recuperado el 22 de julio de 2026, de <https://ccnadesdecero.es/que-es-gns3-como-usarlo/>

X2. Anexos